Hybrid Attacks and Identities in Motion

The Anatomy of Modern Attack Paths

Elad Shamir
Will Schroeder

Agenda

01 Authentication, authorization, and what's in between

02 Identities at-rest, identities in-transit, and credential material

03 Security dependencies and clean source principle

04 Access graph vs. attack graph

05 What makes a hybrid path?

06 Case study: Salesloft-Drift breach

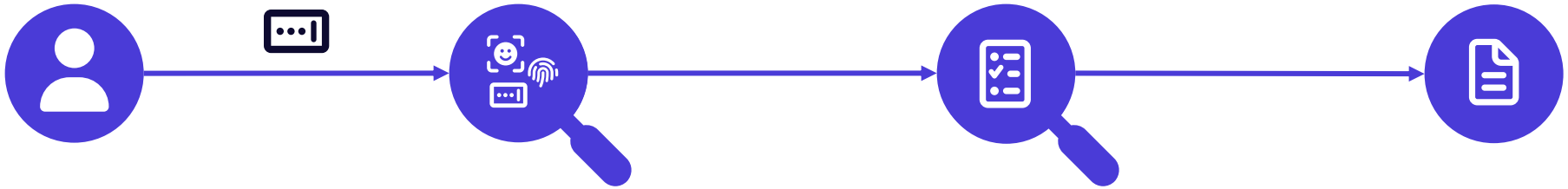
07 Attack Path Management with OpenGraph

Authorization Is Downstream From Authentication

Tell me who you are, and I'll tell you what you can access

Authorization Is Downstream From Authentication

- Every modern ecosystem has a mechanism, or a set of mechanisms, that **governs access to resources**
- These mechanisms must handle **authentication** and **authorization**
  - **Authentication:** Verifying the **identity** of the **principal**
  - **Authorization:** Determining whether the **principal** is permitted to perform an **action** on a **resource**
- A principal must first be **authenticated**, and only then should the system determine whether access is **authorized**



Authorization Is Downstream From Authentication

- Every modern ecosystem has a mechanism, or a set of mechanisms, that **governs access to resources**
- These mechanisms must handle **authentication** and **authorization**
  - **Authentication:** Verifying the **identity** of the **principal**
  - **Authorization:** Determining whether the **principal** is permitted to perform an **action** on a **resource**
- A principal must first be **authenticated**, and only then should the system determine whether access is **authorized**

Identities at Rest vs. Identities in Transit Comparison

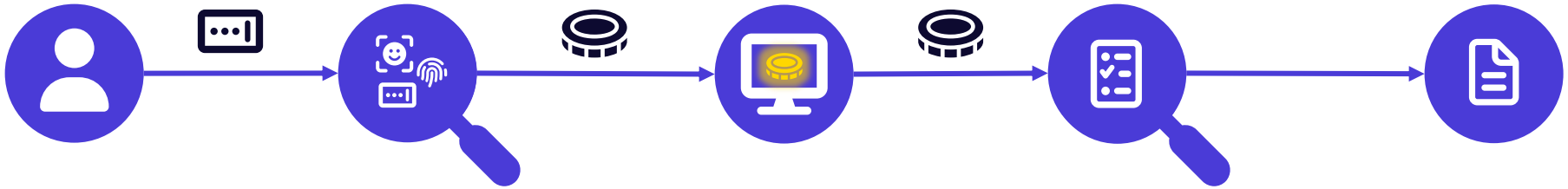
Identities at Rest	Identities in Transit
Stored credentials	Kerberos tickets and access tokens in Windows environments
Group memberships or role assignments	Browser cookies and OAuth tokens in federated/cloud platforms
Access policies tied to the identity object	Primary refresh tokens (PRTs) and their derivatives in hybrid systems

The Flow Is Only as Secure as the Weakest Link

- If the **user** is compromised, the **resource** can be compromised
- If the **credentials** or the **token** are compromised, the **user** can be compromised
- If the **computer** is compromised, the **token** can be compromised
- **Transitivity** applies
  - Computer -> Token -> User -> Resource
- This is the idea behind one of the most important security principles

The Flow Is Only as Secure as the Weakest Link

- If the **user** is compromised, the **resource** can be compromised
- If the **credentials** or the **token** are compromised, the **user** can be compromised
- If the **computer** is compromised, the **token** can be compromised
- **Transitivity** applies
  - Computer -> Token -> User -> Resource
- This is the idea behind one of the most important security principles



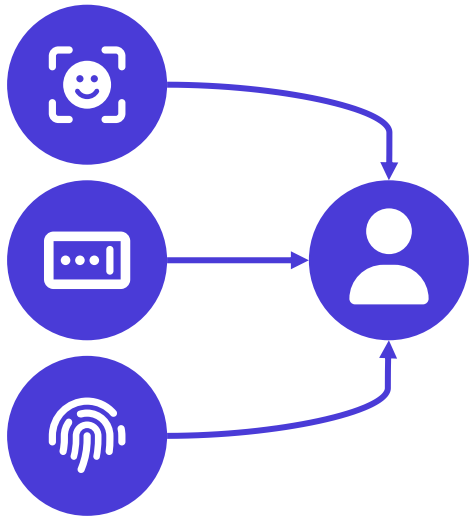
The Clean Source Principle

All security dependencies must be as trustworthy as the object being secured

The Clean Source Principle

All security dependencies must be as trustworthy as the object being secured

- **This simple security principle is the foundation of Attack Path Theory**
  - **An Attack Path is a chain of control relationships with at least one Clean Source Principle violation**
- Compromising a security dependency *may* allow controlling resources that depend on it
  - Some attacks have multiple prerequisites
  - Compromising a single security dependency may be insufficient for controlling a resource that depends on it
    - Example: MFA



The Clean Source Principle

All security dependencies must be as trustworthy as the object being secured

- **This simple security principle is the foundation of Attack Path Theory**
  - **An Attack Path is a chain of control relationships with at least one Clean Source Principle violation**
- Compromising a security dependency may allow controlling resources that depend on it
  - Some attacks have multiple prerequisites
  - Compromising a single security dependency may be insufficient for controlling a resource that depends on it
    - Example: MFA
- **Control is transitive**
  - If A controls B and B controls C, then A controls C

Typical Hardening Steps

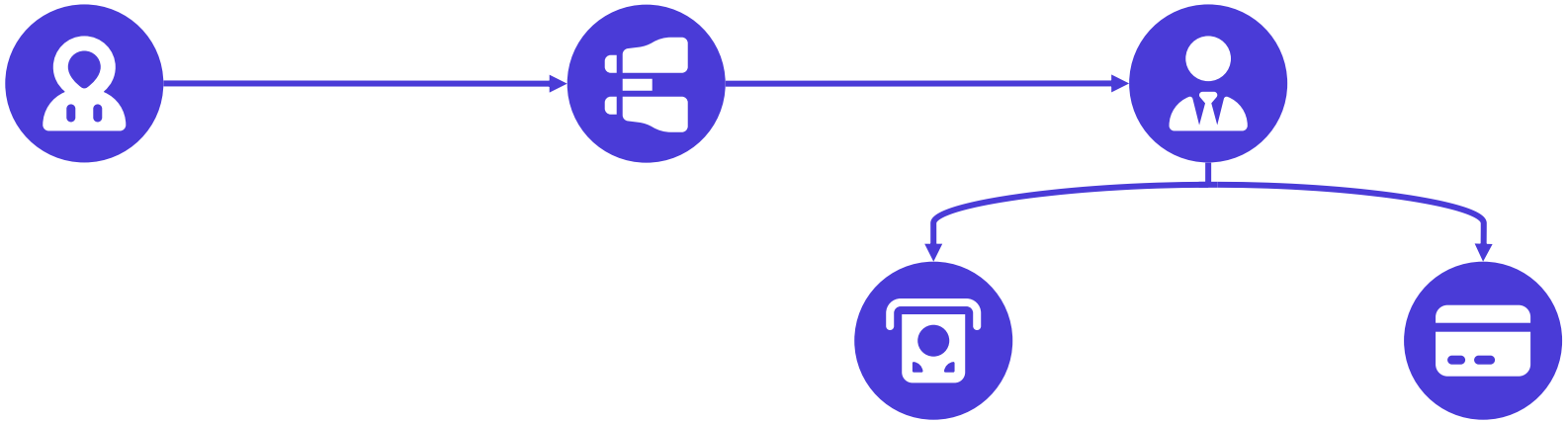
- **Identity security tends to focus on identity at rest**, with controls such as:
  - Network policy rules
  - Multi-Factor Authentication (MFA)
  - Conditional Access Policy (CAP)
  - Anomalous login detection
  - Password rotation (periodically or post-breach)
- **These controls *typically* don't affect identities in transit**
- Attackers often seek to gain access to ephemeral credential material to hijack active sessions

What Would You Do?

If you could only choose one… which pocket would you reach for?

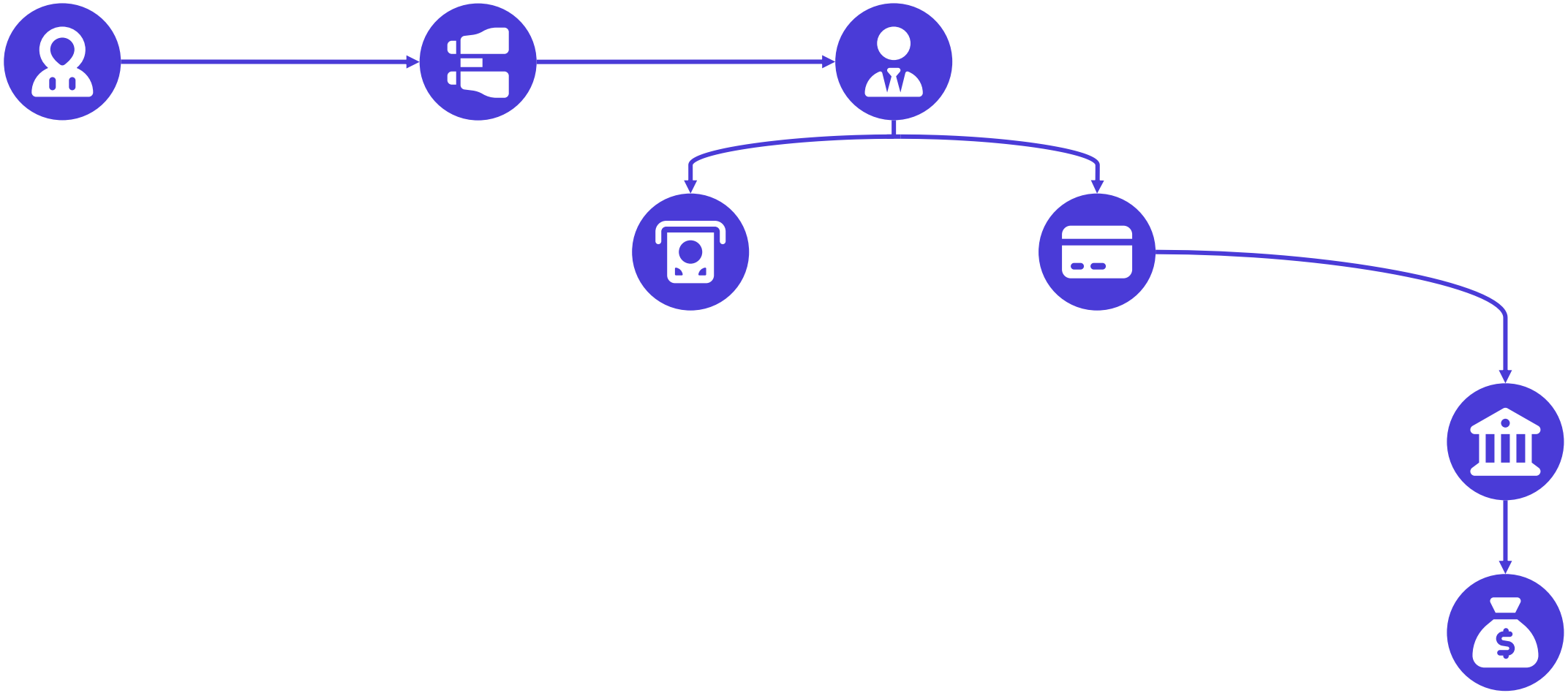
What Would You Do?

If you could only choose one... which pocket would you reach for?



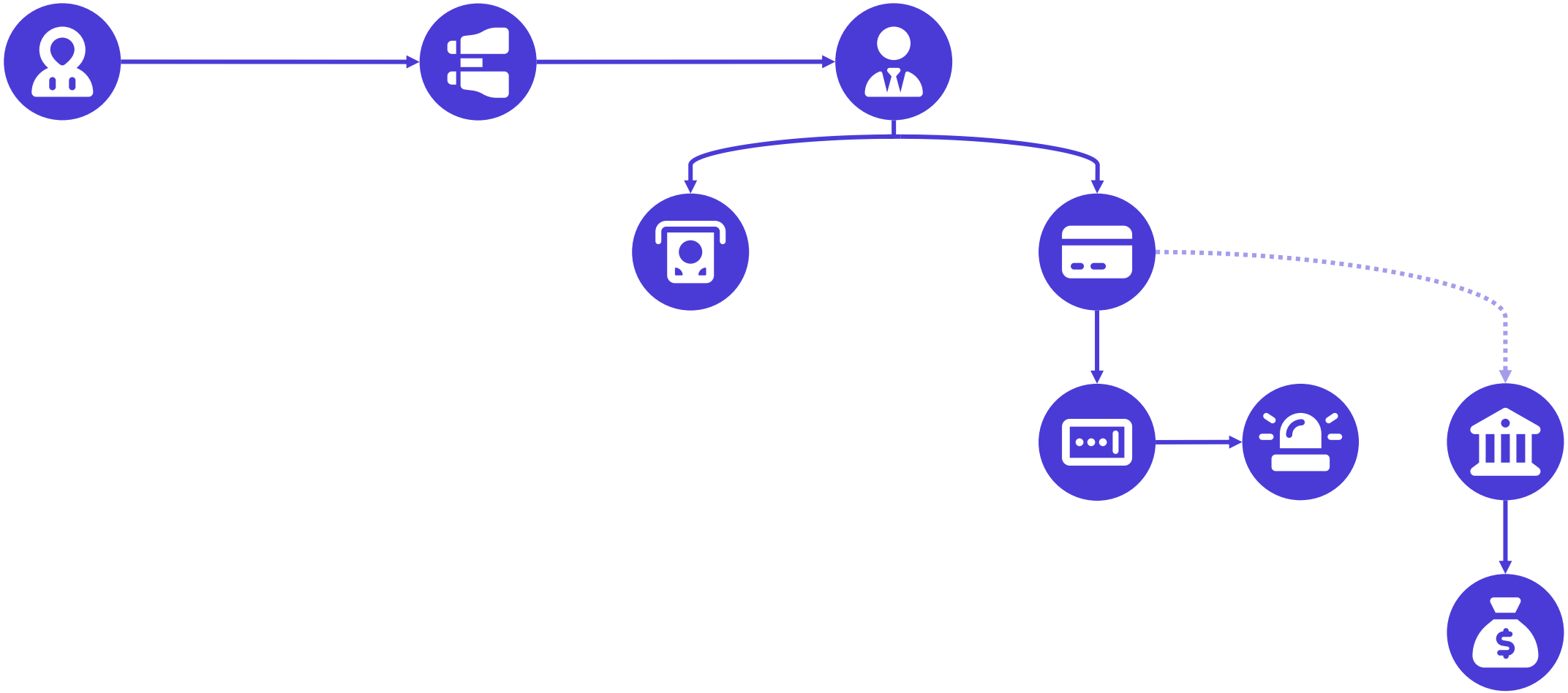
What Would You Do?

If you could only choose one... which pocket would you reach for?



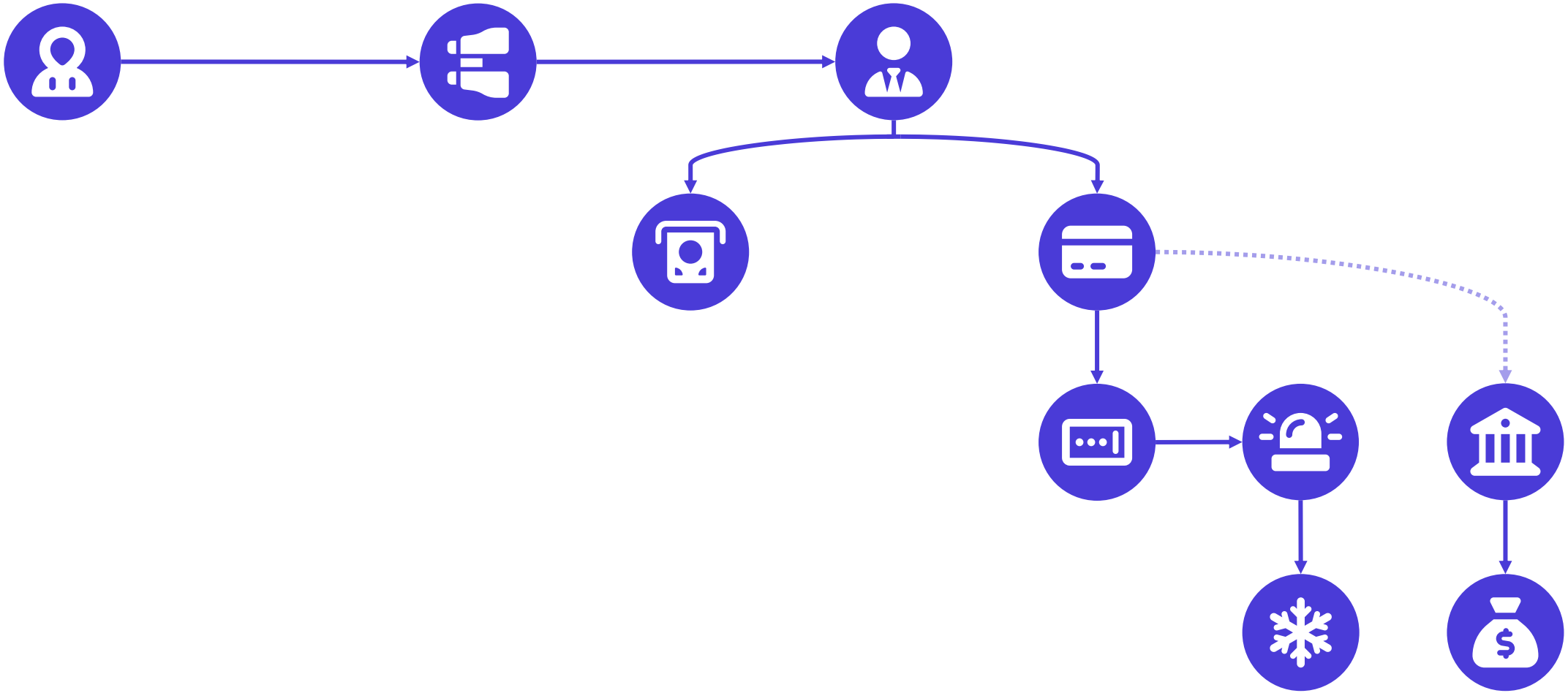
What Would You Do?

If you could only choose one... which pocket would you reach for?



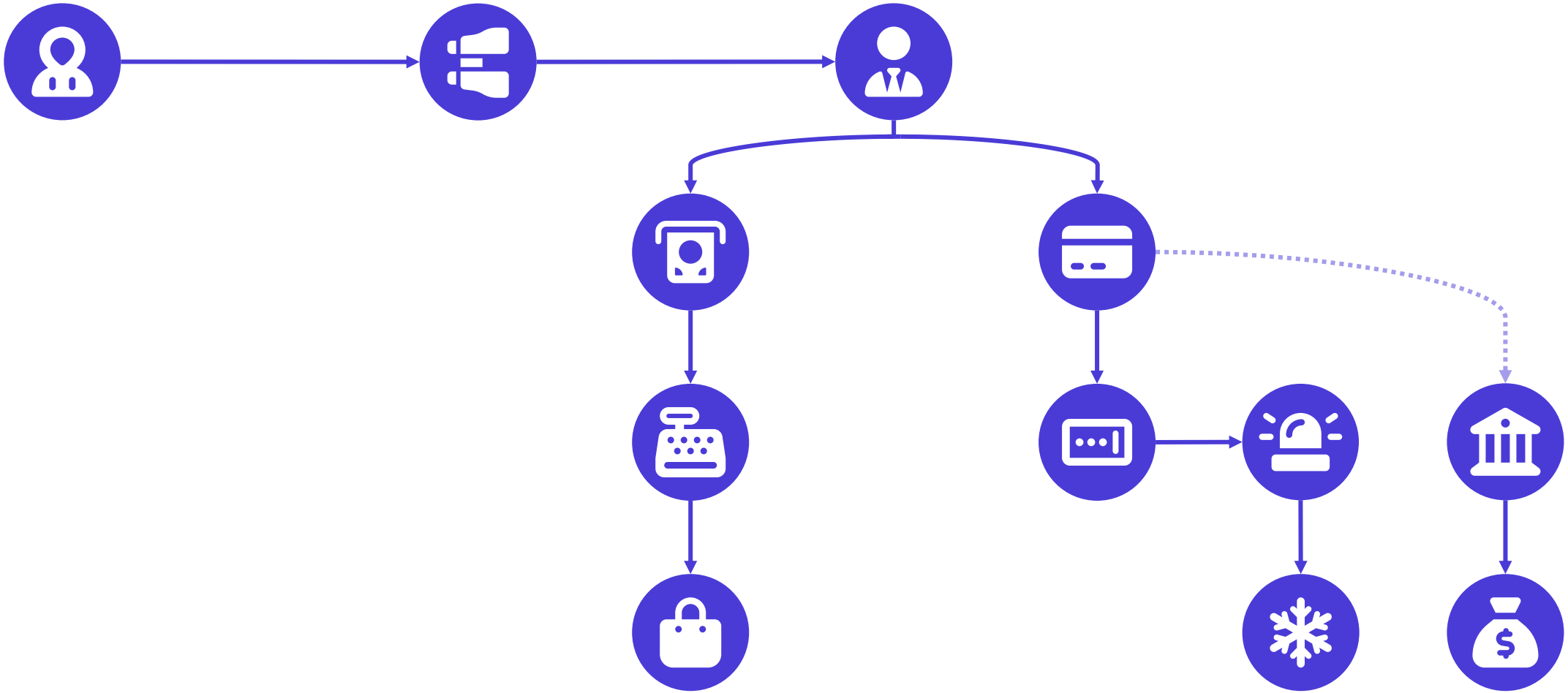
What Would You Do?

If you could only choose one... which pocket would you reach for?



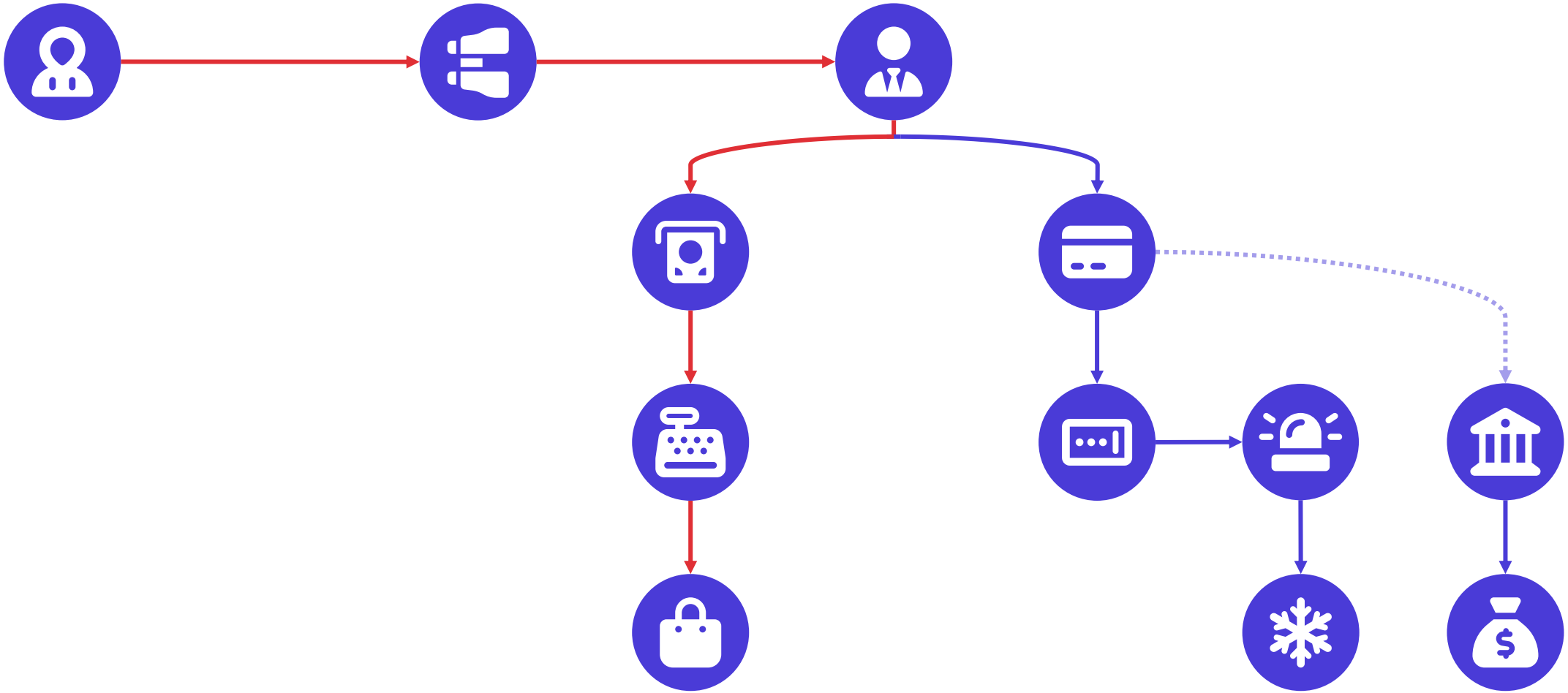
What Would You Do?

If you could only choose one... which pocket would you reach for?



What Would You Do?

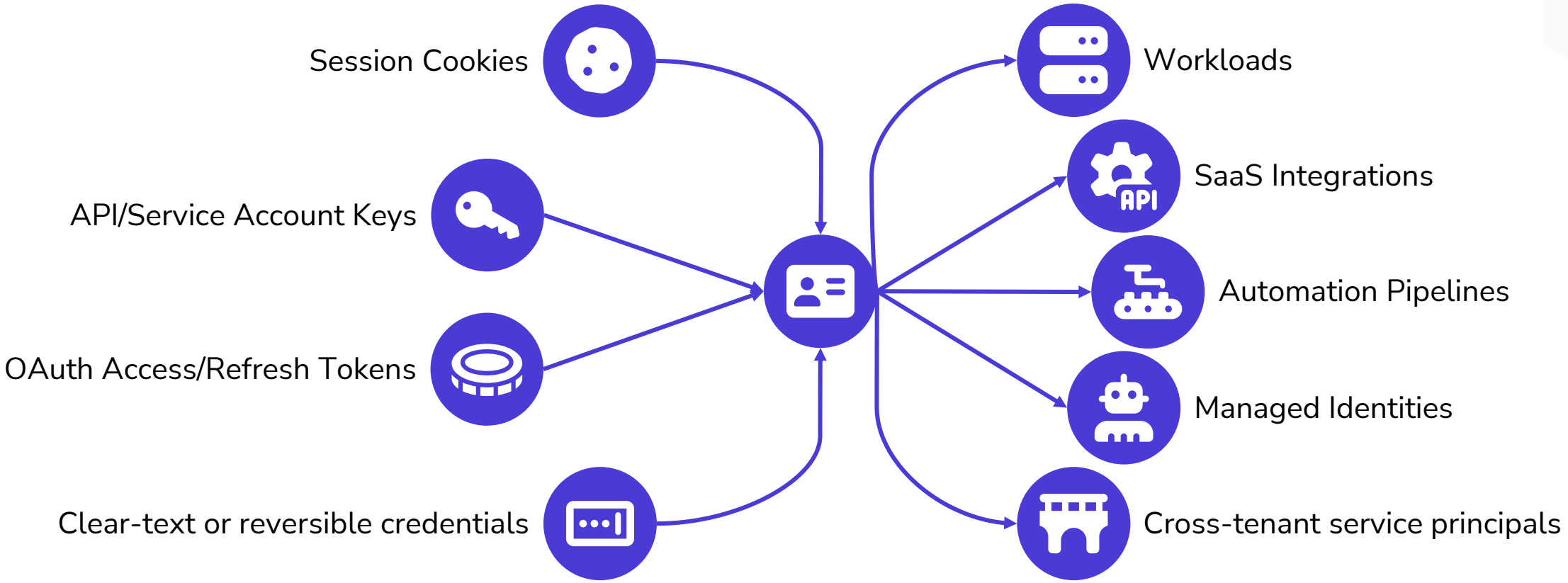
If you could only choose one... which pocket would you reach for?



Authentication Is Also Downstream From Authorization

Tell me what I can access, and I'll tell you whom I can become

Credentials Are Everywhere



The Missing Link Between the Access Graph and the Attack Graph

Access Graph

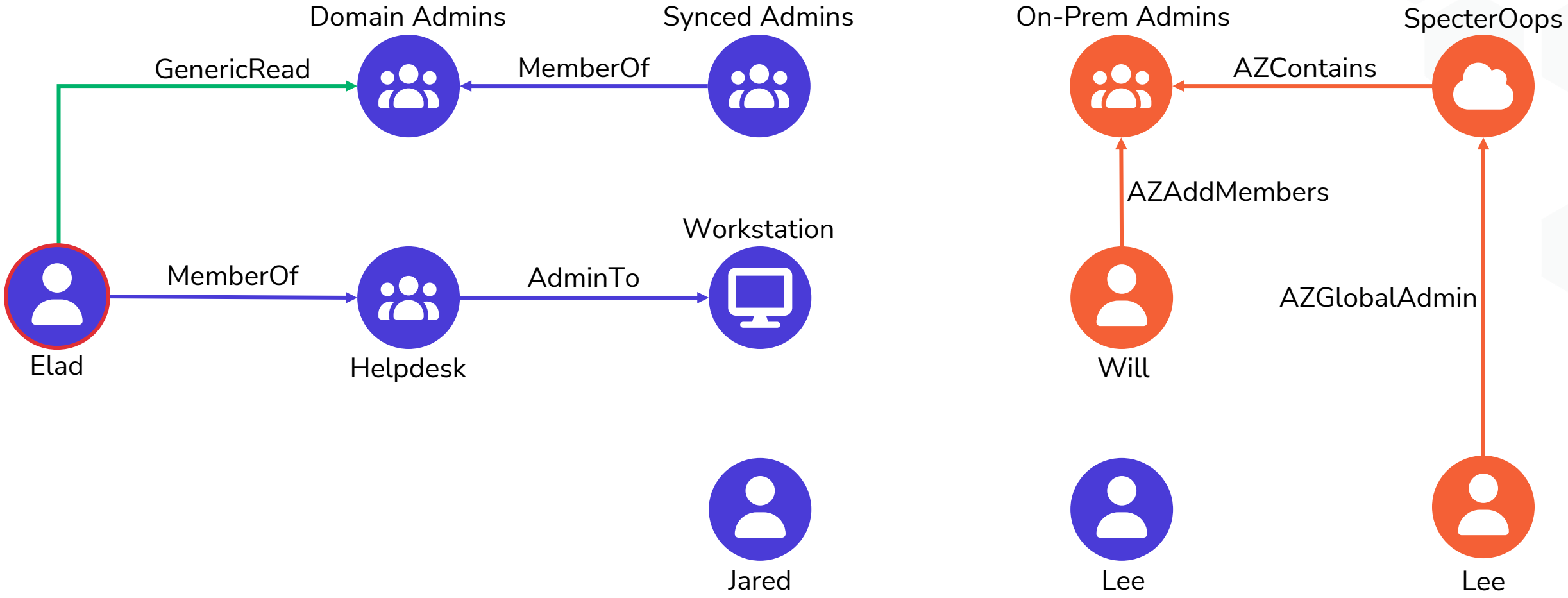
- A representation of the **access control model**
- Aims to depict **all access** permitted in the system, making it **susceptible to false positives in pathfinding**
- Connects **identities to resources**
- Follows the **Authentication -> Authorization paradigm**
- Limited to **authorization** – shows only identities at rest
- Minimal hybrid path support, mostly as an afterthought

Attack Graph

- A representation of **how an adversary can move** through the system **by abusing control relationships**
- Depicts **only the abusable access** permitted in the system
- Connects **identities to resources, resources to identities, and identities to identities**
- Follows both the **Authentication -> Authorization** and the **Authorization -> Authentication paradigms**
- **Includes identities in transit**
- Can inherently show **hybrid attack paths**

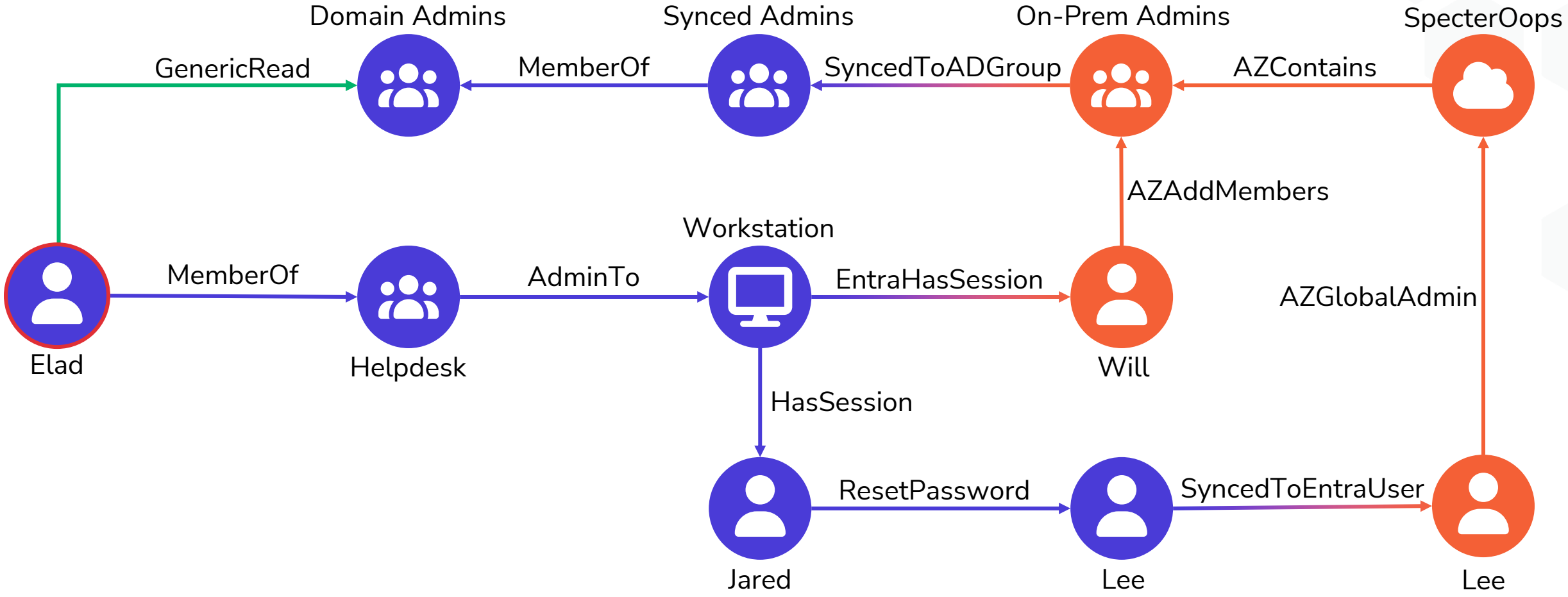
Access Graph vs. Attack Graph Example

Access Graph



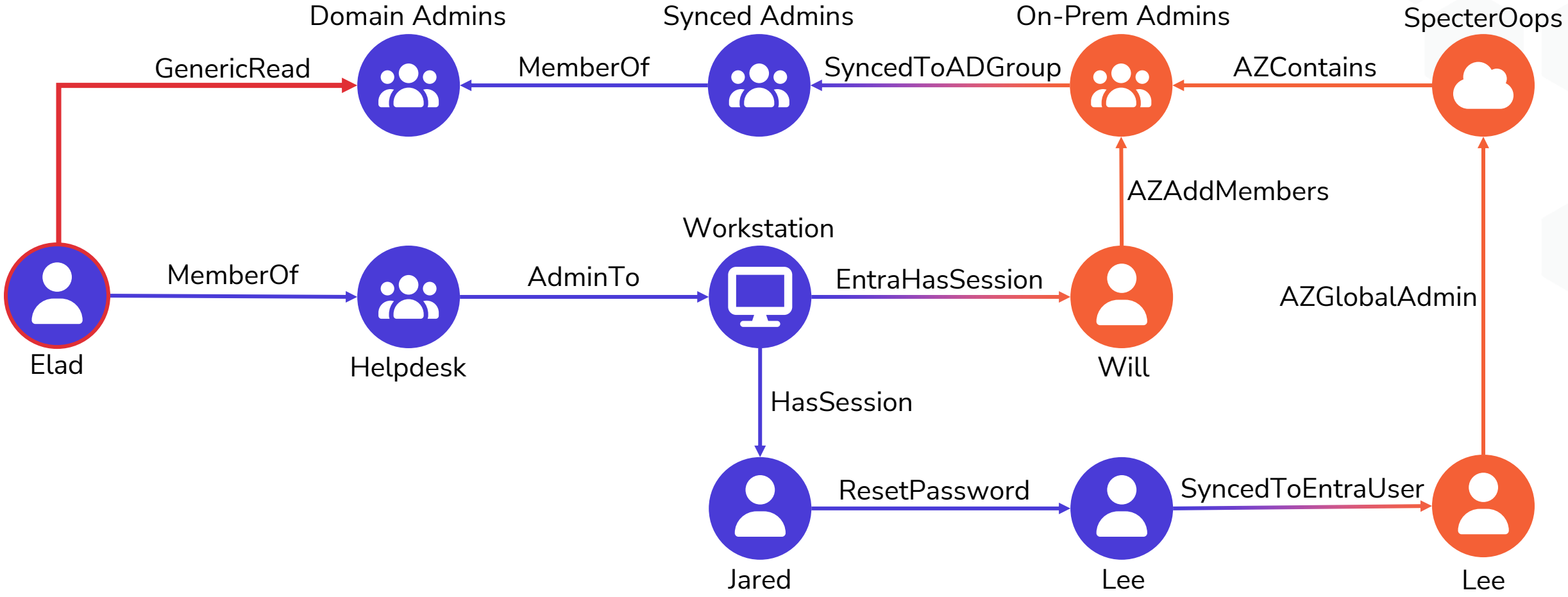
Access Graph vs. Attack Graph Example

Access Graph and Attack Graph



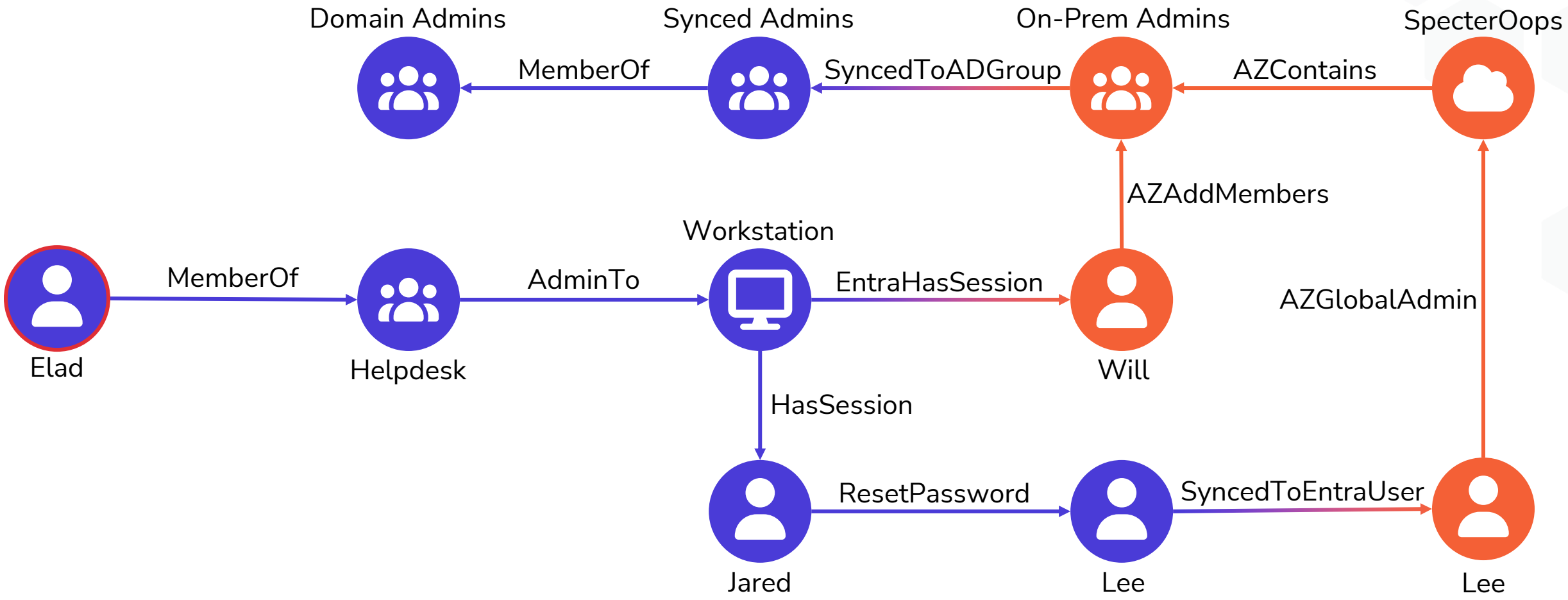
Access Graph vs. Attack Graph Example

Access Graph and Attack Graph



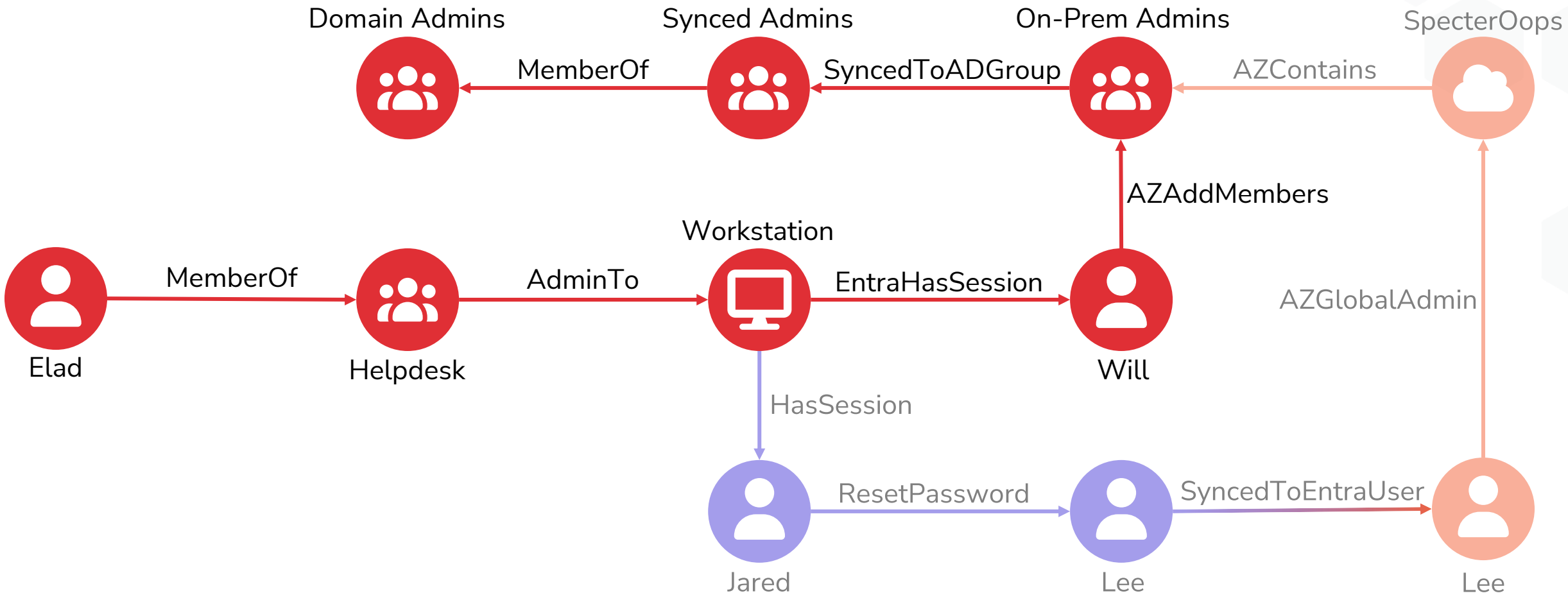
Access Graph vs. Attack Graph Example

Attack Graph



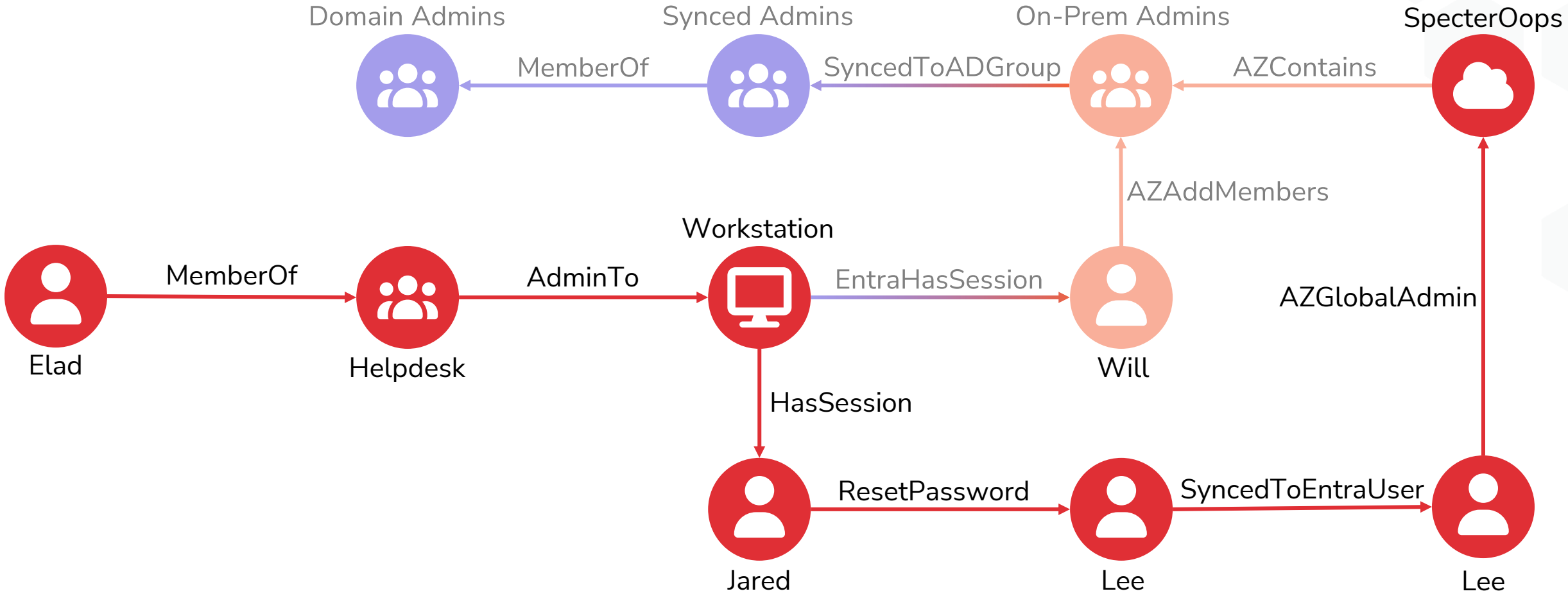
Access Graph vs. Attack Graph Example

Path Finding to Domain Admins



Access Graph vs. Attack Graph Example

Path Finding to Global Admin



What Makes a Hybrid Path?

What Makes a Hybrid Attack Path?

- Hybrid attack paths consist of at least one hybrid edge that connects an identity/resource on one platform to an identity/resource on another platform/environment/organization
- Hybrid edges can represent several types of relationships, such as:

A cross-platform synchronization mechanism

An interconnected authentication system

An interconnected authorization system

Device management capabilities

Credential material for an identity in one platform stored on a resource in another platform

What Makes a Hybrid Attack Path?

Cross-Platform Synchronization Mechanism

- The simplest hybrid path is a result of a synchronization mechanism between two platforms
  - **Password Hash Synchronization (PHS)**
- These simple mechanisms usually rely on an agent/service on one or both platforms

What Makes a Hybrid Attack Path?

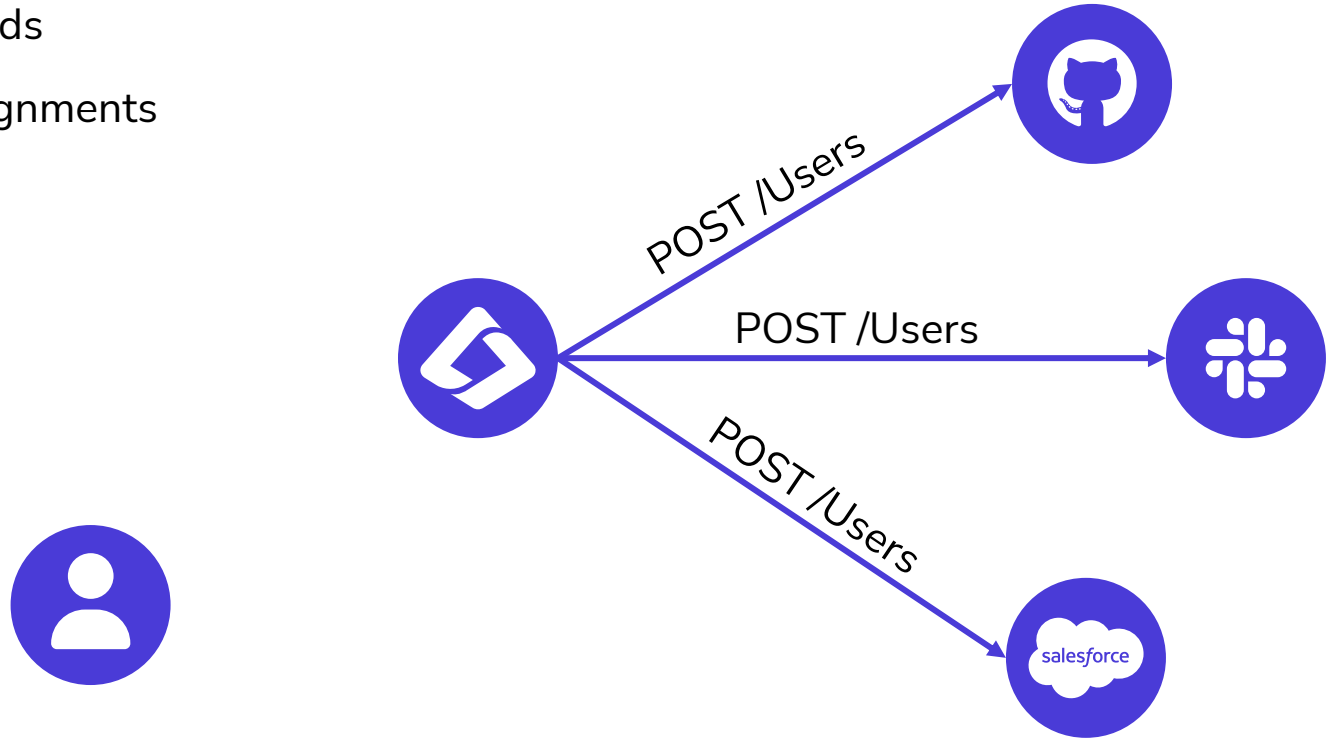
Cross-Platform Synchronization Mechanism

- **System for Cross-domain Identity Management (SCIM)** is an open standard protocol that automates user identity lifecycle management across cloud-based applications
  - Provisioning, updating, and de-provisioning
  - Uses RESTful APIs and JSON to **synchronize user data between Identity Providers (IdPs) and Service Providers (SPs)**
    - CRUD operations via standard HTTP methods
  - Can control group memberships and role assignments

What Makes a Hybrid Attack Path?

Cross-Platform Synchronization Mechanism

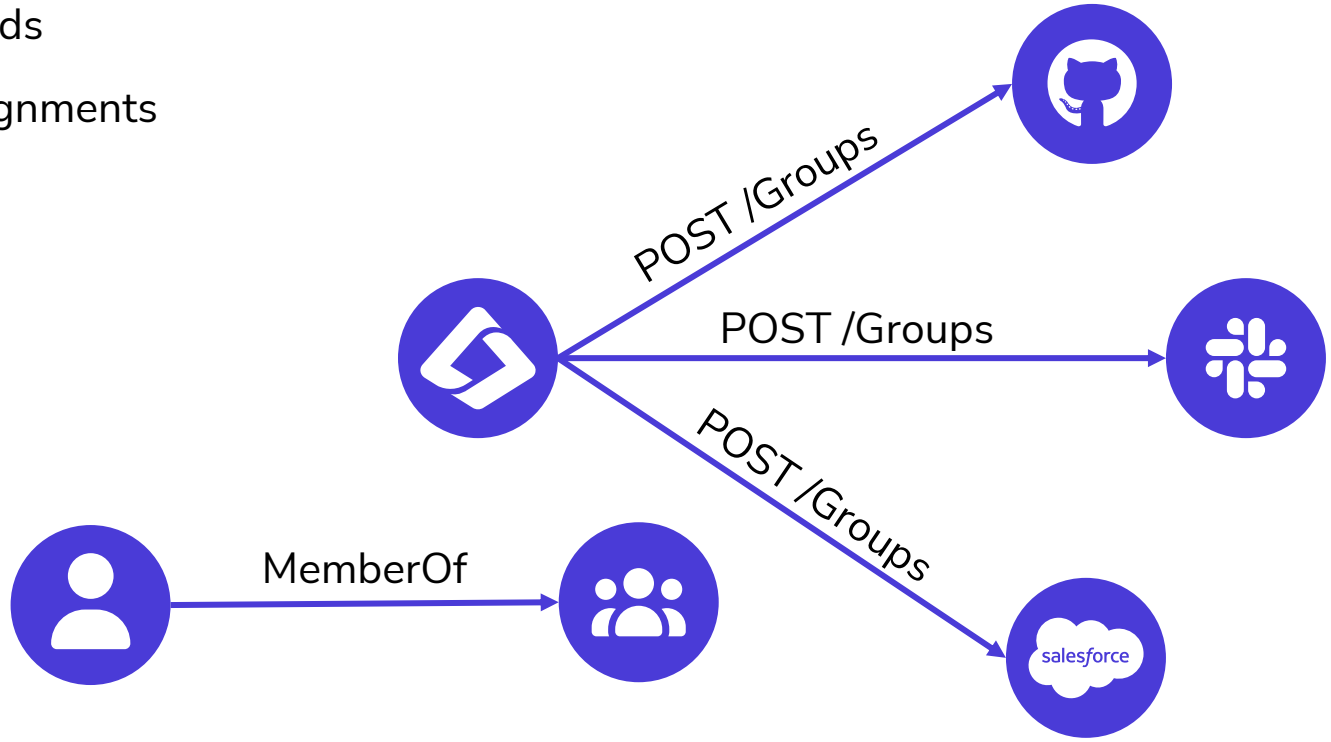
- **System for Cross-domain Identity Management (SCIM)** is an open standard protocol that automates user identity lifecycle management across cloud-based applications
  - Provisioning, updating, and de-provisioning
  - Uses RESTful APIs and JSON to **synchronize user data between Identity Providers (IdPs) and Service Providers (SPs)**
    - CRUD operations via standard HTTP methods
  - Can control group memberships and role assignments



What Makes a Hybrid Attack Path?

Cross-Platform Synchronization Mechanism

- **System for Cross-domain Identity Management (SCIM)** is an open standard protocol that automates user identity lifecycle management across cloud-based applications
  - Provisioning, updating, and de-provisioning
  - Uses RESTful APIs and JSON to **synchronize user data between Identity Providers (IdPs) and Service Providers (SPs)**
    - CRUD operations via standard HTTP methods
  - Can control group memberships and role assignments



What Makes a Hybrid Attack Path?

Cross-Platform Synchronization Mechanism: SCIM Abuse

- Some SCIM implementations can synchronize passwords as well

What Makes a Hybrid Attack Path?

Cross-Platform Synchronization Mechanism: SCIM Abuse

- **Some SCIM implementations can synchronize passwords as well**
- An attack called "**PassBleed**" abuses this mechanism in **Okta**
  - Allows an App Administrator to create or hijack a SCIM application and siphon passwords
  - **The attack affects Super Admins, leading to privilege escalation**
- Similarly, an attacker with the right permissions on the IdP can potentially have downstream effects on group memberships, role assignments, or user mapping on other platforms

What Makes a Hybrid Attack Path?

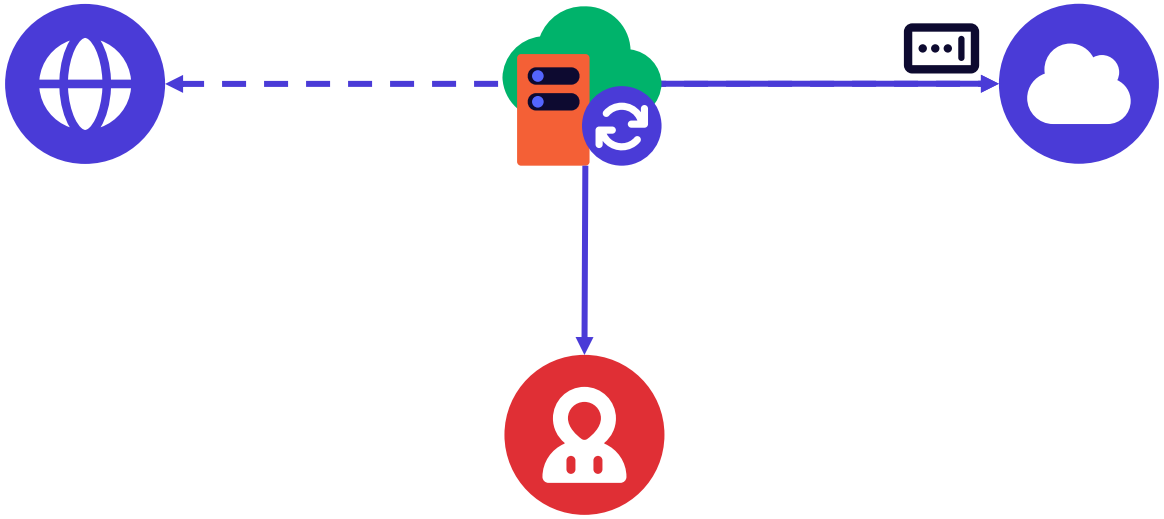
Interconnected Authentication/Authorization System

- There are several ways to federate authentication or authorization from one platform to another
  - **Pass Through Authentication (PTA)**
    - An **agent** receives authentication requests from one platform and validates the credentials against another

What Makes a Hybrid Attack Path?

Interconnected Authentication/Authorization System

- There are several ways to federate authentication or authorization from one platform to another
  - **Pass Through Authentication (PTA)**
    - An **agent** receives authentication requests from one platform and validates the credentials against another
    - Compromising the agent allows **stealing credentials or creating a skeleton key to impersonate any hybrid account**



What Makes a Hybrid Attack Path?

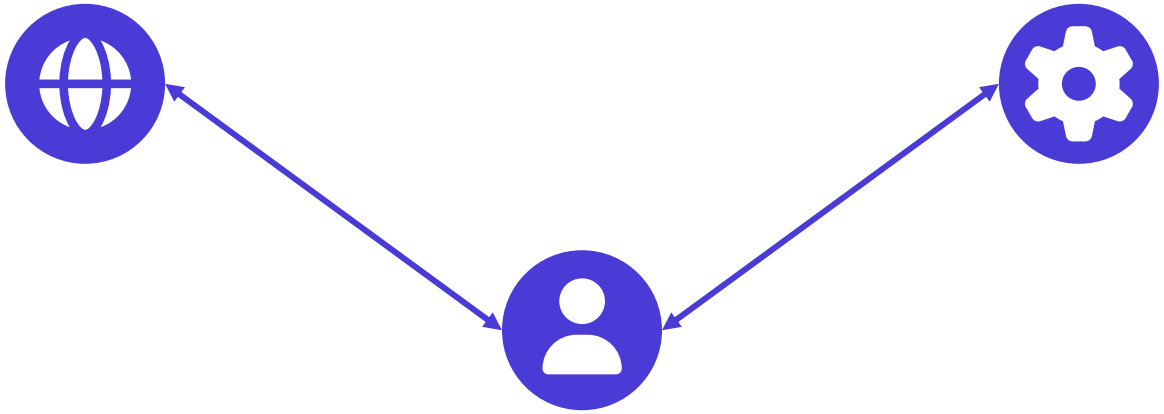
Interconnected Authentication/Authorization System

- There are several ways to federate authentication or authorization from one platform to another
  - **SAML**
    - An XML-based open standard for **exchanging authentication and authorization data between an Identity Provider (IdP) and a Service Provider (SP)**

What Makes a Hybrid Attack Path?

Interconnected Authentication/Authorization System

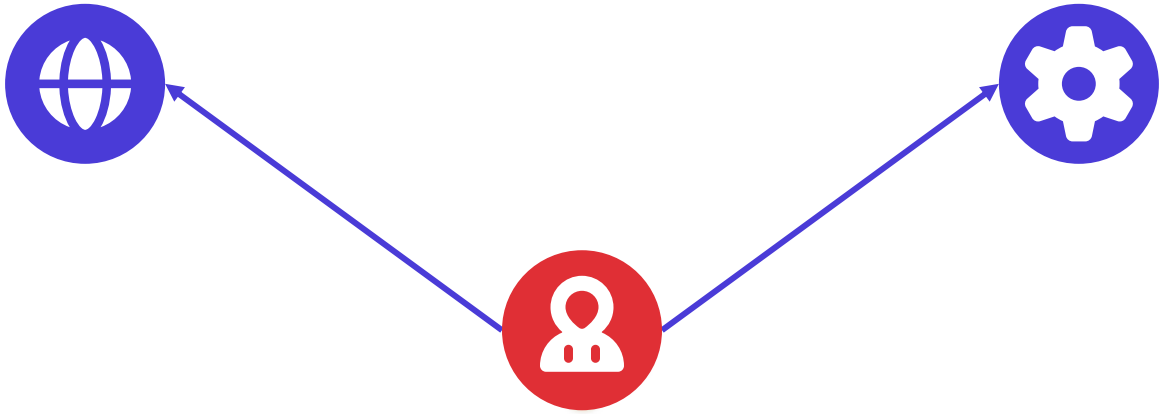
- There are several ways to federate authentication or authorization from one platform to another
  - **SAML**
    - An XML-based open standard for **exchanging authentication and authorization data between an Identity Provider (IdP) and a Service Provider (SP)**
    - **Used primarily for authentication**, but SAML assertions can contain information that affects user mapping, permissions, role assignments, or group memberships on the Service Provider's side



What Makes a Hybrid Attack Path?

Interconnected Authentication/Authorization System

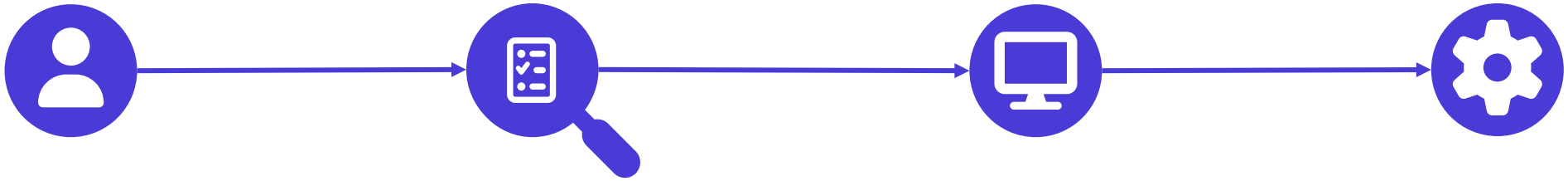
- There are several ways to federate authentication or authorization from one platform to another
  - **SAML**
    - An XML-based open standard for **exchanging authentication and authorization data between an Identity Provider (IdP) and a Service Provider (SP)**
    - **Used primarily for authentication**, but SAML assertions can contain information that affects user mapping, permissions, role assignments, or group memberships on the Service Provider's side
    - Stealing the IdP's private key or installing a rogue SAML provider allows performing the "**Golden SAML attack**" by forging a SAML assertion to **impersonate users or spoof authorization information**



What Makes a Hybrid Attack Path?

Interconnected Authentication/Authorization System

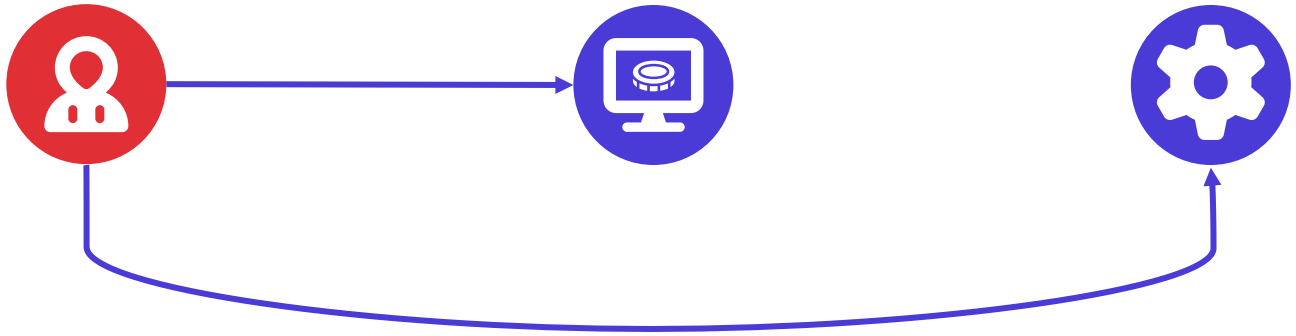
- There are several ways to federate authentication or authorization from one platform to another
  - **OAuth**
    - OAuth is an **authorization framework** that allows granting access to applications (**consent**) and obtaining **Access Tokens**



What Makes a Hybrid Attack Path?

Interconnected Authentication/Authorization System

- There are several ways to federate authentication or authorization from one platform to another
  - **OAuth**
    - OAuth is an **authorization framework** that allows granting access to applications (**consent**) and obtaining **Access Tokens**
    - **Stealing OAuth access/refresh tokens is one of the most common modern attacks against identities in transit**



What Makes a Hybrid Attack Path?

Interconnected Authentication/Authorization System

- There are several ways to federate authentication or authorization from one platform to another
  - **OAuth**
    - OAuth is an **authorization framework** that allows granting access to applications (**consent**) and obtaining **Access Tokens**
    - **Stealing OAuth access/refresh tokens is one of the most common modern attacks against identities in transit**
    - **OIDC** is an OAuth **extension** that issues **Identity Tokens** to support **authentication** as well

What Makes a Hybrid Attack Path?

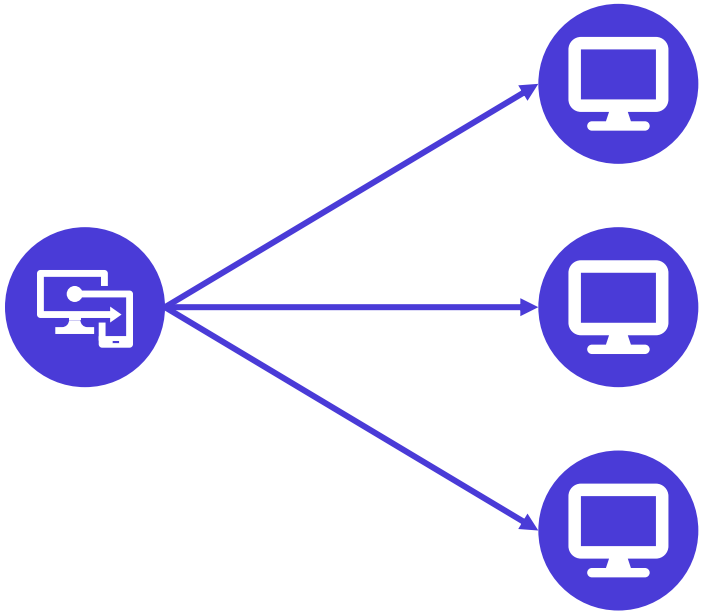
Interconnected Authentication/Authorization System

- There are several ways to federate authentication or authorization from one platform to another
  - “Protocol Transition”
    - The term is commonly associated with Kerberos delegation, but can apply to any scenario in which a service allows users to authenticate via one protocol/platform, and then facilitates authentication via another
      - Kerberos ticket to token with Entra Seamless Single Sign-On or Okta Desktop Single Sign-on
      - Token to Kerberos ticket with Entra Cloud Kerberos Trust
      - Kerberos/NTLM to SAML via ADFS
    - **Compromising the bridging service typically allows impersonating arbitrary hybrid accounts**

What Makes a Hybrid Attack Path?

Device Management Capabilities

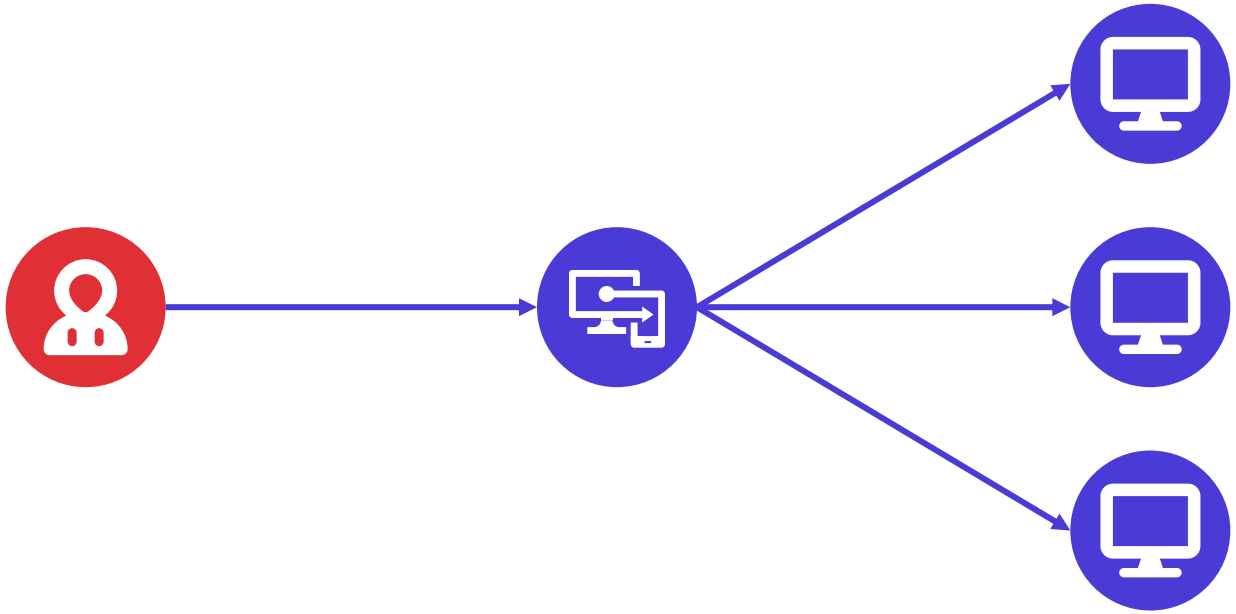
- Unified Endpoint Management (UEM) solutions, like Intune and Jamf, can execute code on managed devices
  - Deploy applications/configurations/policies
  - Inventory/health/compliance monitoring
  - Troubleshooting/support capabilities



What Makes a Hybrid Attack Path?

Device Management Capabilities

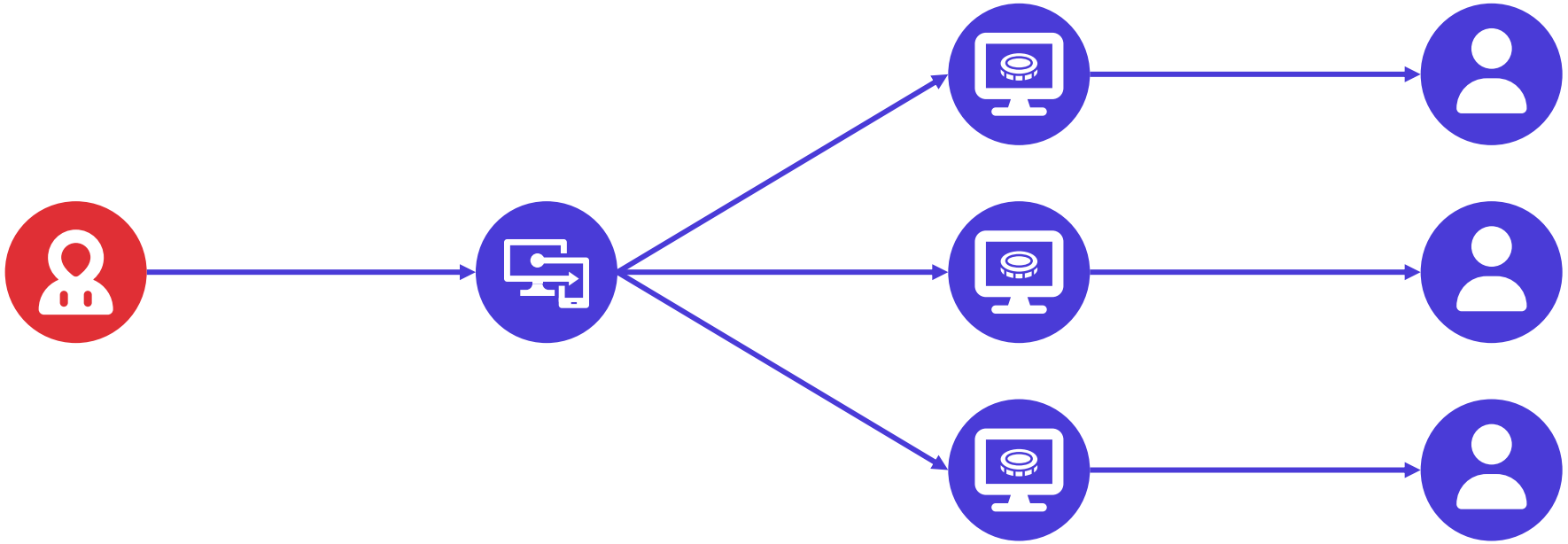
- Unified Endpoint Management (UEM) solutions, like Intune and Jamf, can execute code on managed devices
  - Deploy applications/configurations/policies
  - Inventory/health/compliance monitoring
  - Troubleshooting/support capabilities
- Gaining access to UEM solutions allows compromising managed devices and **hijacking all the active sessions on them**



What Makes a Hybrid Attack Path?

Device Management Capabilities

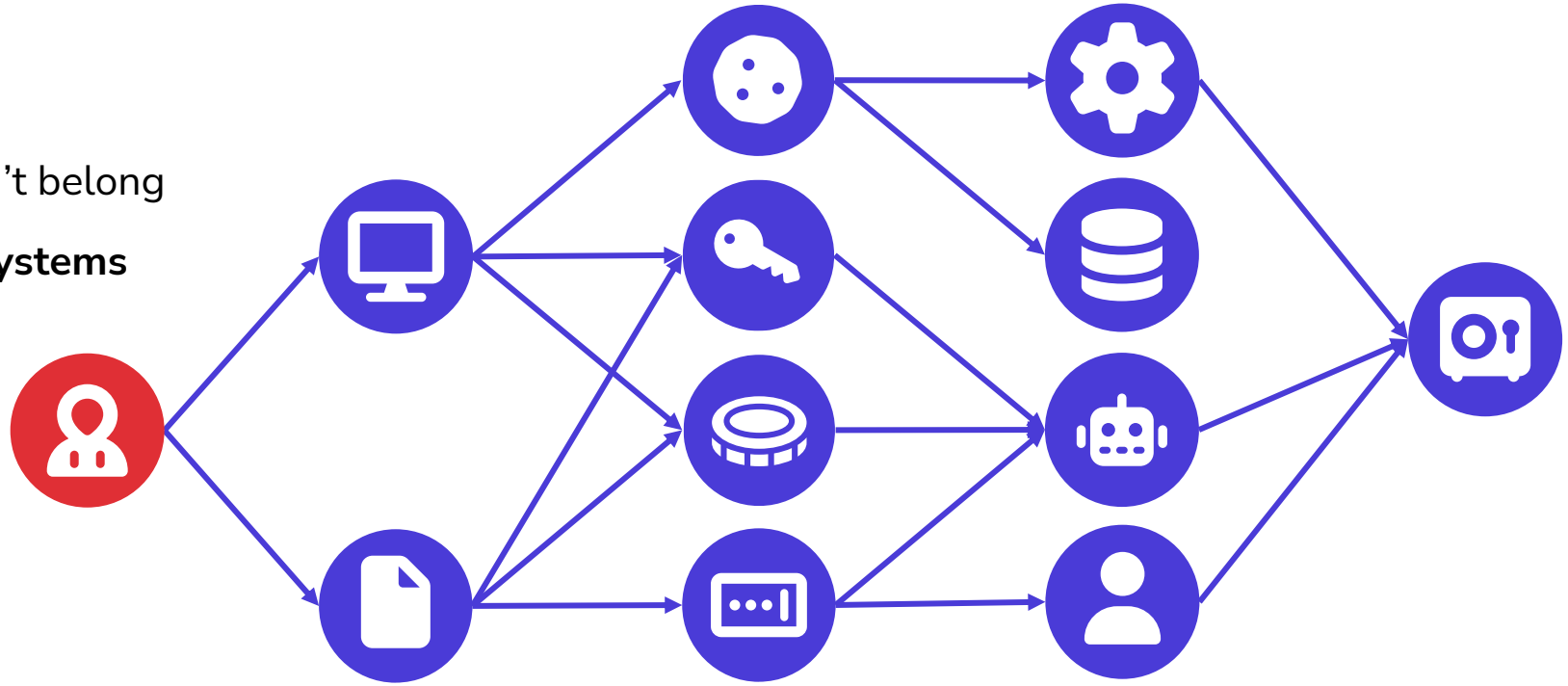
- Unified Endpoint Management (UEM) solutions, like Intune and Jamf, can execute code on managed devices
  - Deploy applications/configurations/policies
  - Inventory/health/compliance monitoring
  - Troubleshooting/support capabilities
- Gaining access to UEM solutions allows compromising managed devices and **hijacking all the active sessions on them**



What Makes a Hybrid Attack Path?

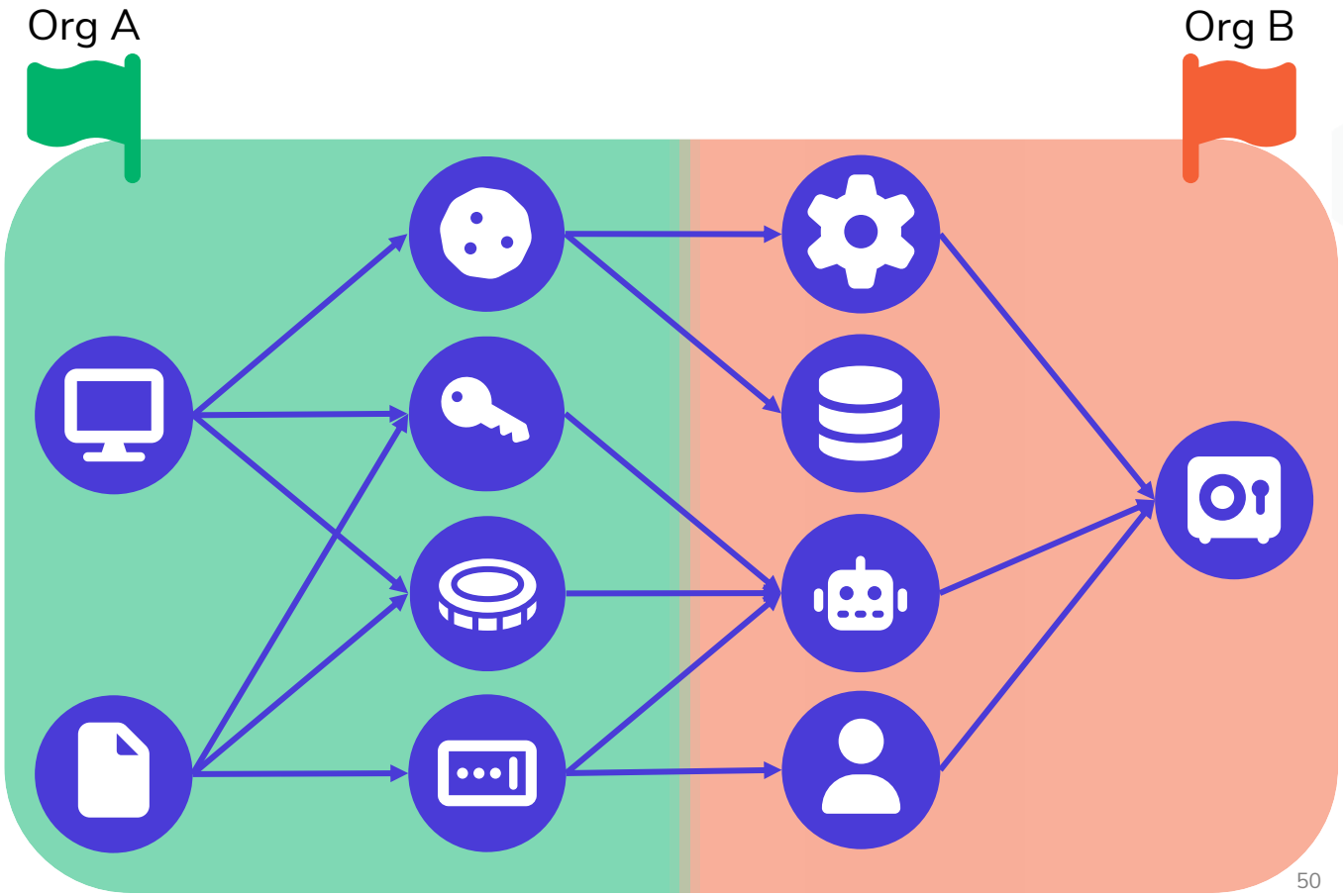
Credential Material for an Identity in One Platform Stored on a Resource in Another Platform

- The most common hybrid path is a result of credential material for an identity from one platform being stored on a resource in another platform
- The classic example is session cookies or tokens to a cloud/SaaS platform stored on an on-prem device
- API keys and access tokens in configuration files and scripts
  - **CI/CD pipelines**
- Password managers
- Clear text passwords where they don't belong
  - **Tickets/notes in CRM or support systems**



Cross-Organizational Hybrid Paths

- Organizations often establish relationships with 3rd parties in a way that creates hybrid paths originating from outside the organization
  - Managed services
  - Integrations
    - AI bots and agents!
  - Good old supply chain attacks

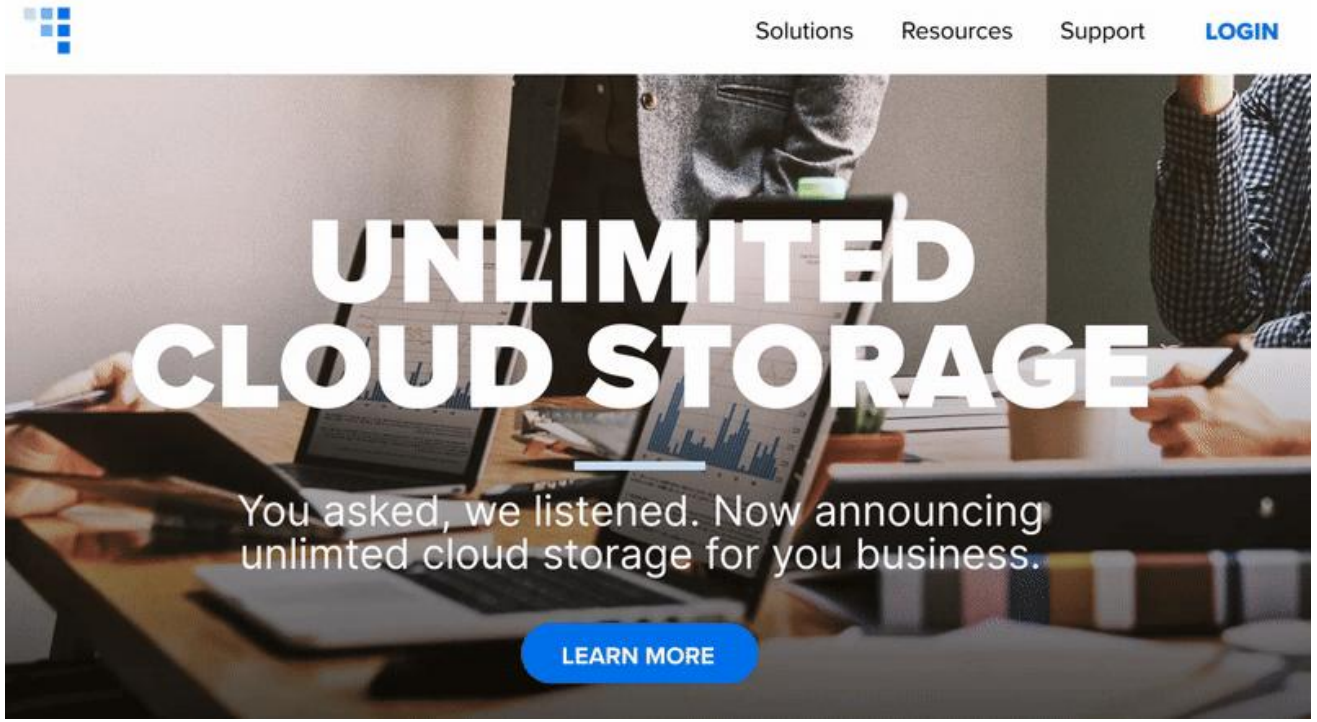


Case Study

Salesloft-Drift Breach

Case Study: Salesloft-Drift Breach

- Salesloft's Drift is an AI bot that helps sales/marketing teams capture and convert leads by automating real-time conversations
- Can integrate directly into CRM workflows, notably in Salesforce via OAuth
- Simple and efficient
- What could go wrong?



Case Study: Salesloft-Drift Breach

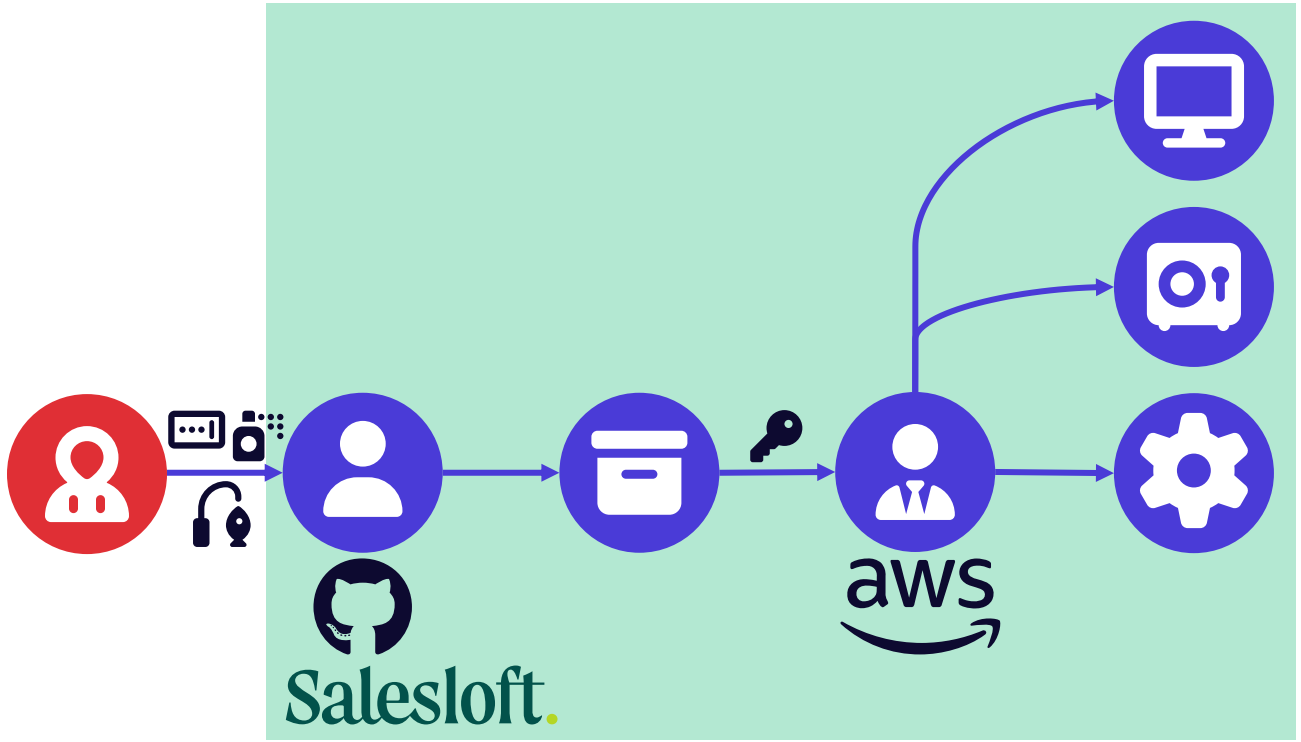
Initial Access

- **March–June 2025:** A threat actor gained access to Salesloft's GitHub organization
  - The exact initial access method was not disclosed
  - Likely phishing or password spraying

Case Study: Salesloft-Drift Breach

AWS Pivot

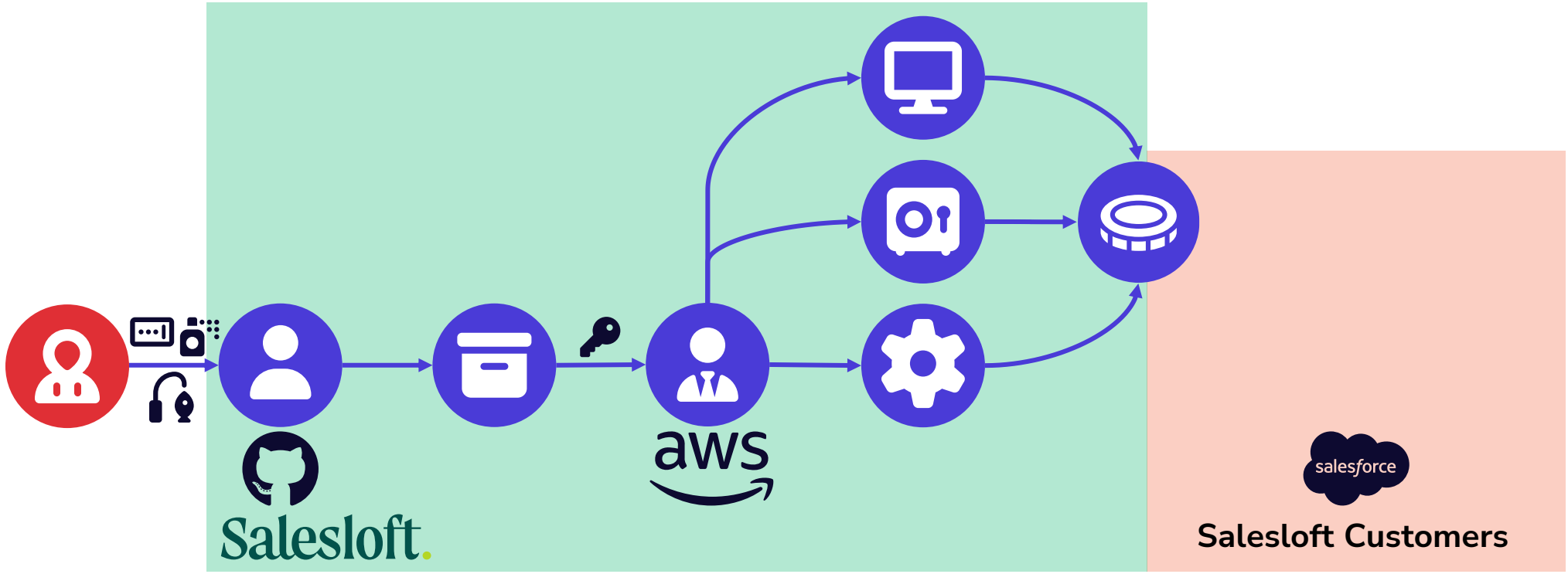
- **June–July 2025:** Salesloft had CI/CD workflows in GitHub that had access to AWS runtime environments, secrets storage
  - Could be done via OIDC or stored AWS access keys



Case Study: Salesloft-Drift Breach

Crossing Organizational Boundaries

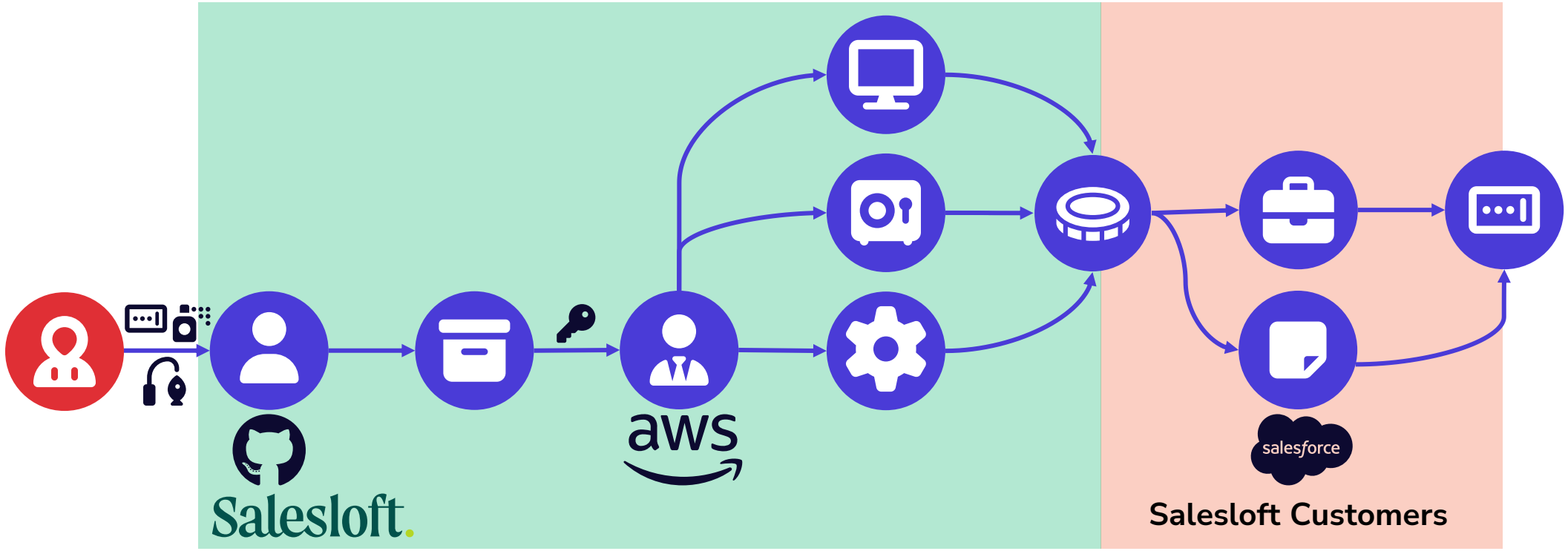
- **August 8–18, 2025:** The attackers found Salesforce access and refresh tokens in AWS
  - Crossing a boundary from Salesloft's environment to Salesloft's customers' environments



Case Study: Salesloft-Drift Breach

Crossing Organizational Boundaries

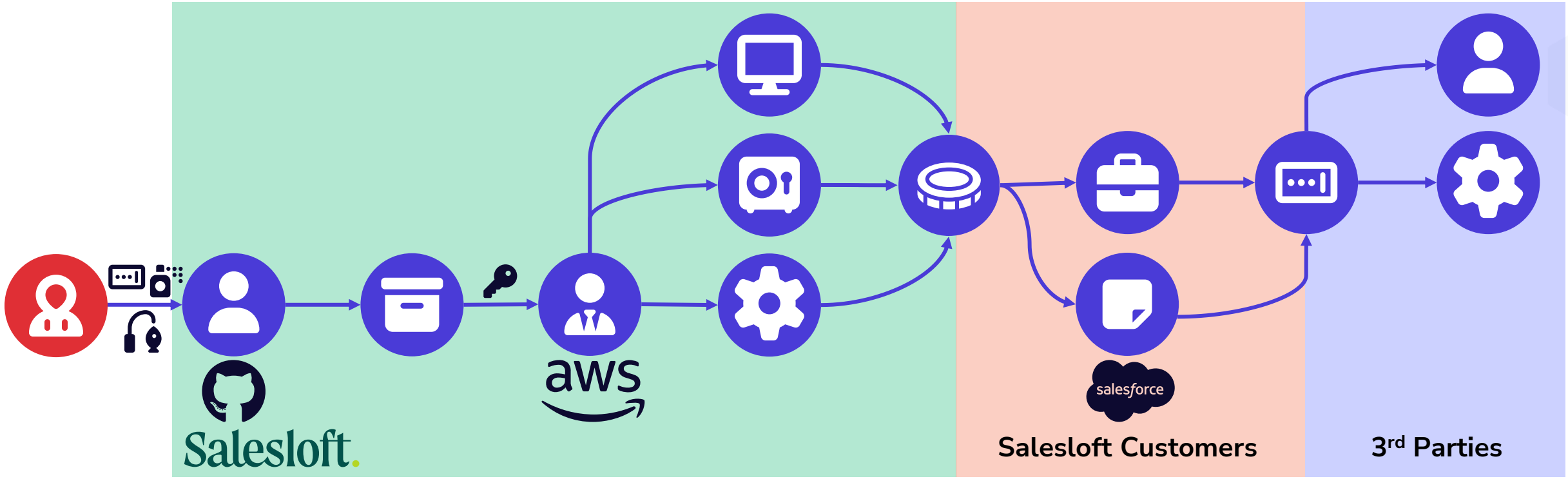
- **August 8–18, 2025:** Some customers stored credential material on Salesforce
  - For example, inside case notes



Case Study: Salesloft-Drift Breach

Crossing Organizational Boundaries

- These credentials could allow the attackers to cross yet another organizational boundary into 3rd party systems
  - Salesloft's customers' customers



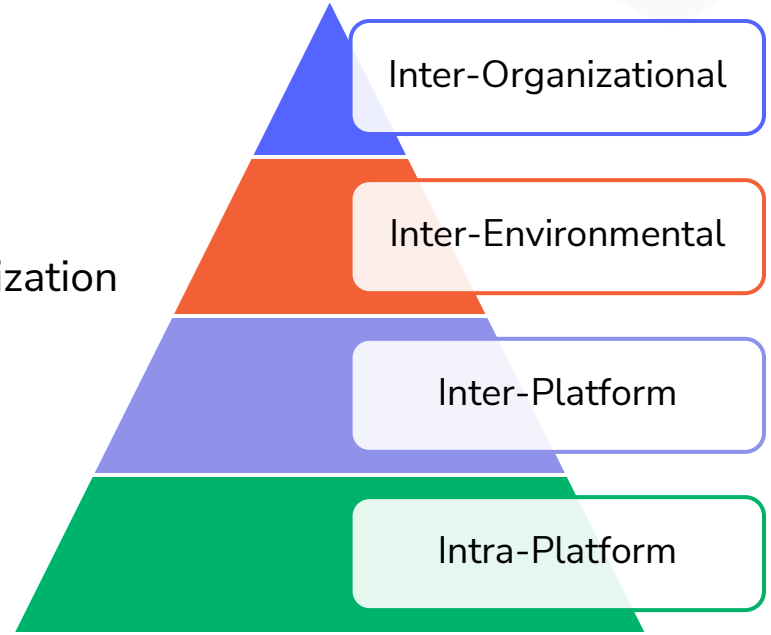
Attack Path Management

Back to first principles

Back to First Principles

"All security dependencies must be as trustworthy as the object being secured"

- Modern environments are built on layers of dependency, and those dependencies inevitably leak trust
- It helps to think about these dependencies on four levels:
  - **Intra-platform** dependencies exist inside a single system
  - **Inter-platform** dependencies span across systems
  - **Inter-environmental** dependencies span across environments in the same organization
  - **Inter-organizational** dependencies span across organizations
- The combination is more dangerous than any system in isolation
  - **When one platform/organization becomes dependent on another, the risk compounds**



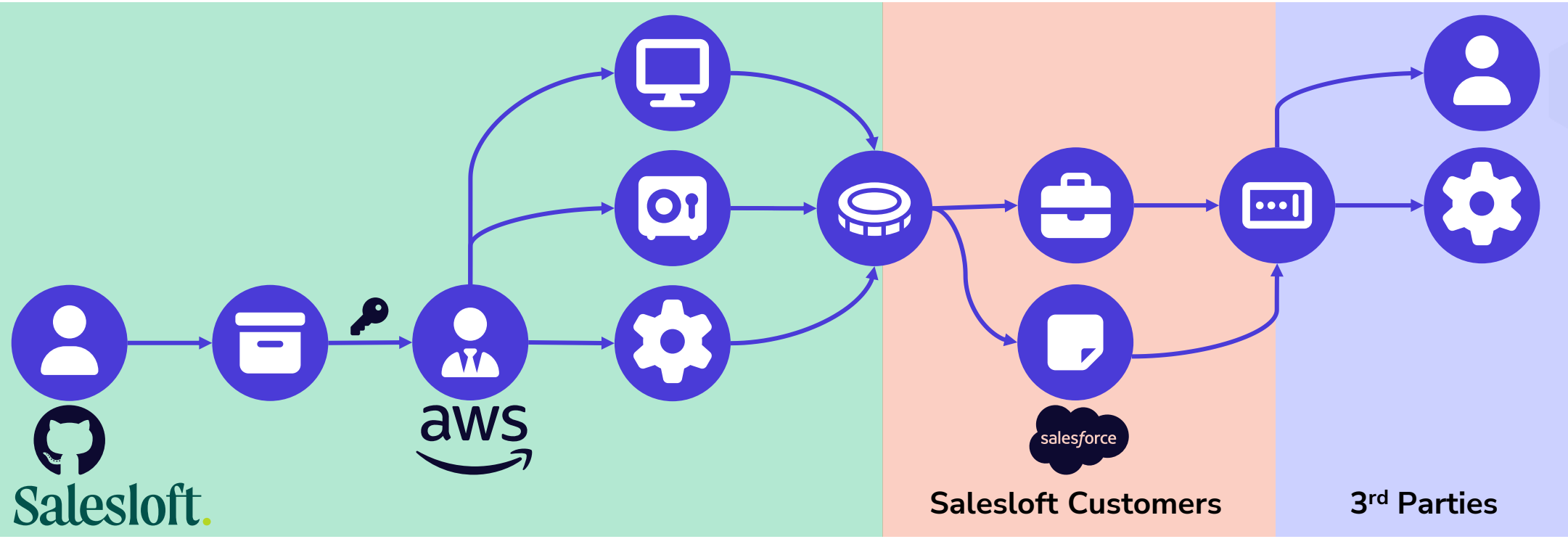
OpenGraph as the Future-Proof Strategy

- **OpenGraph** extends BloodHound beyond AD, allowing organizations to model **any platform**
  - **Allows to see hybrid attack paths**
  - Uncover security dependencies **and clean source principle violations**
    - Privilege Zones can help perform this analysis continuously

OpenGraph as the Future-Proof Strategy

Salesloft Example

- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Remediation Strategies

- There are two primary remediation options:

Remove the security dependency

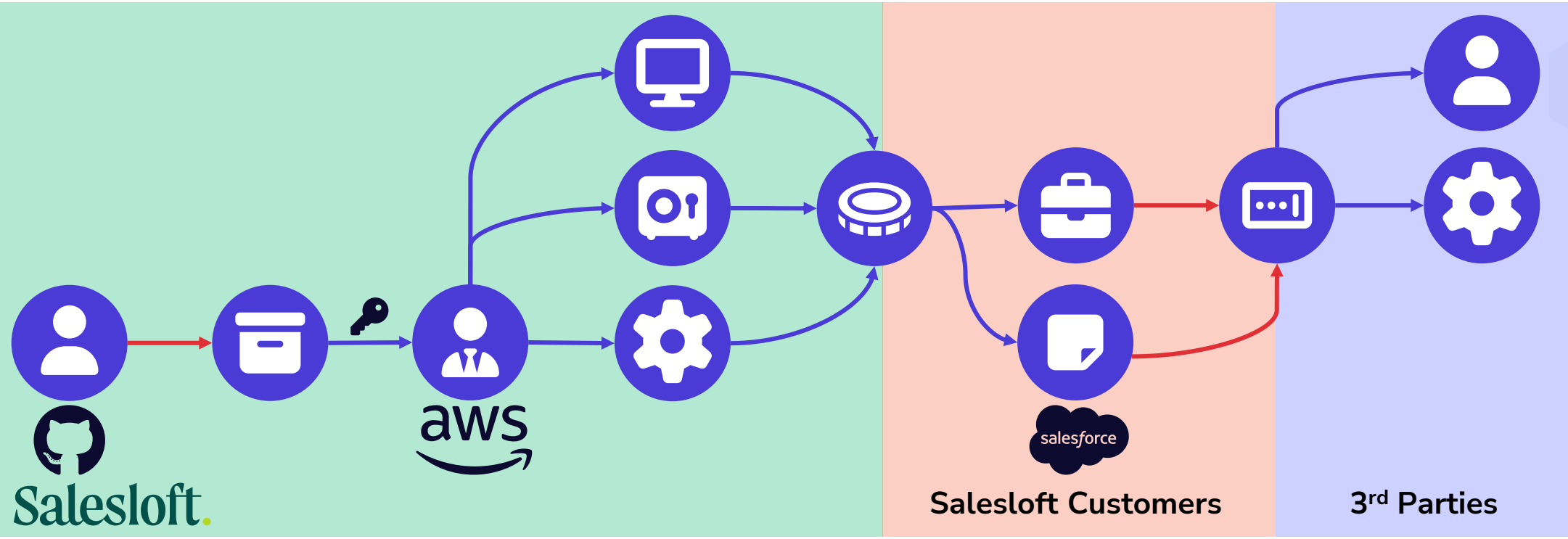
Equalize the trustworthiness level of the resource and the security dependency

  - Add additional security controls to the security dependency
  - Remove functionality or reduce sensitivity from the resource

OpenGraph as the Future-Proof Strategy

Salesloft Example

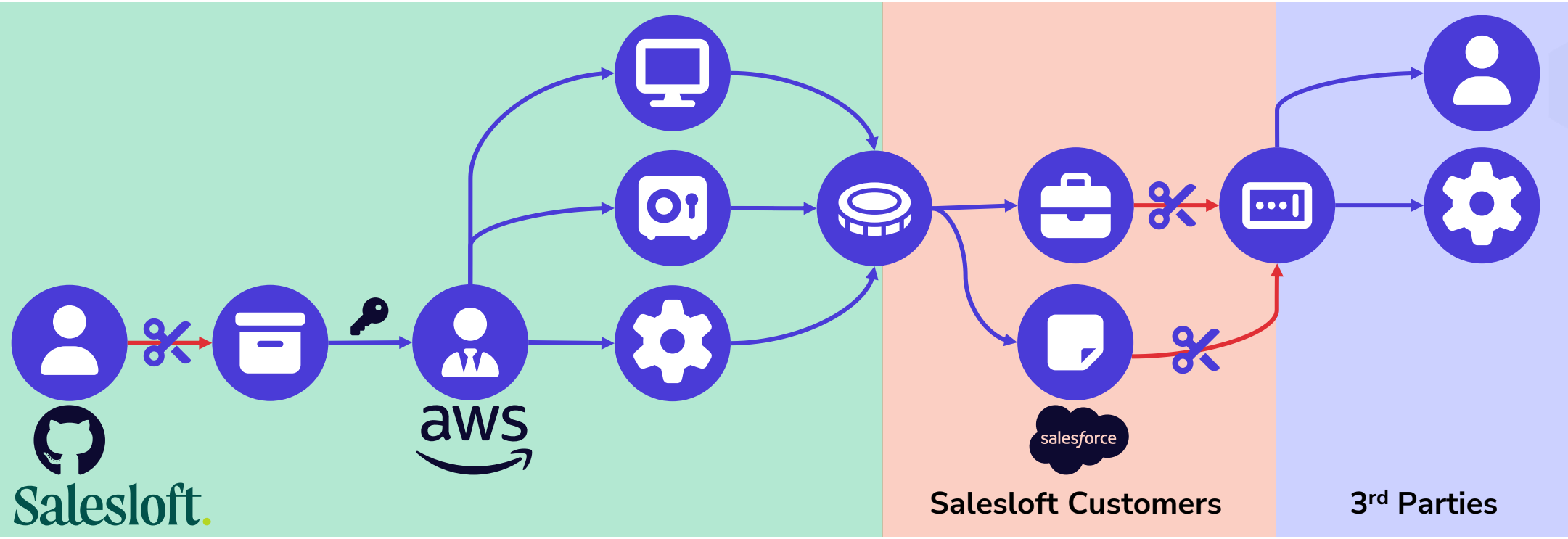
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example: Remove the Security Dependency

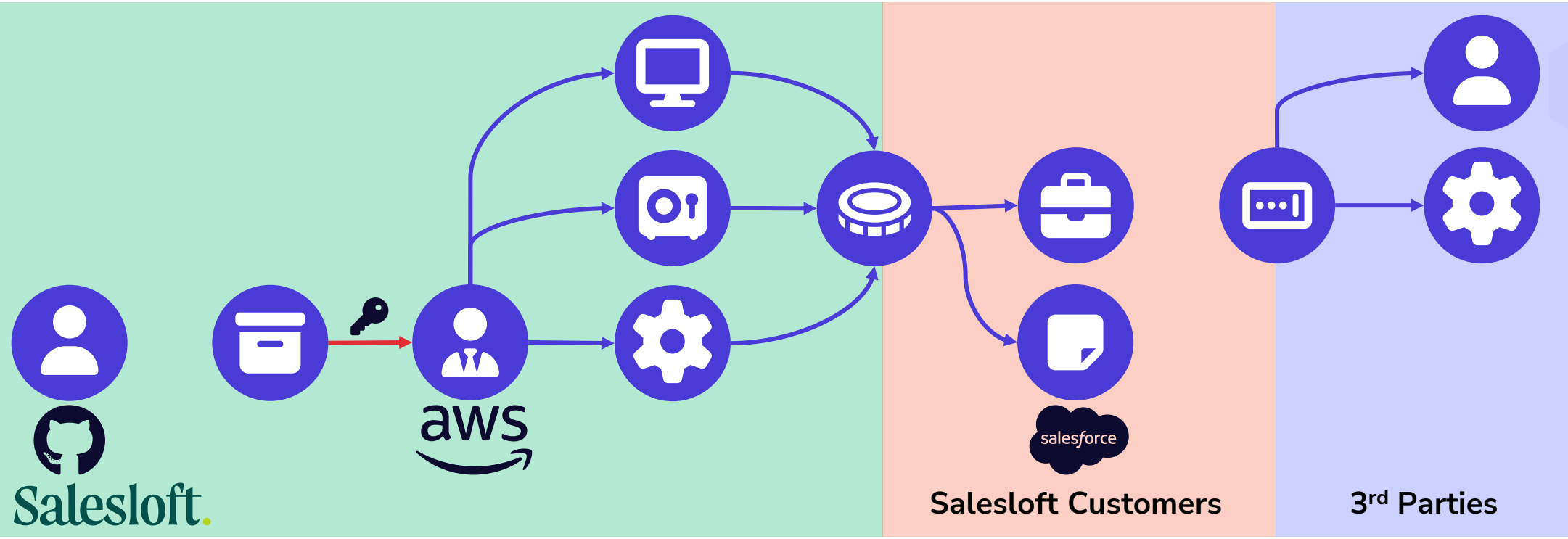
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example

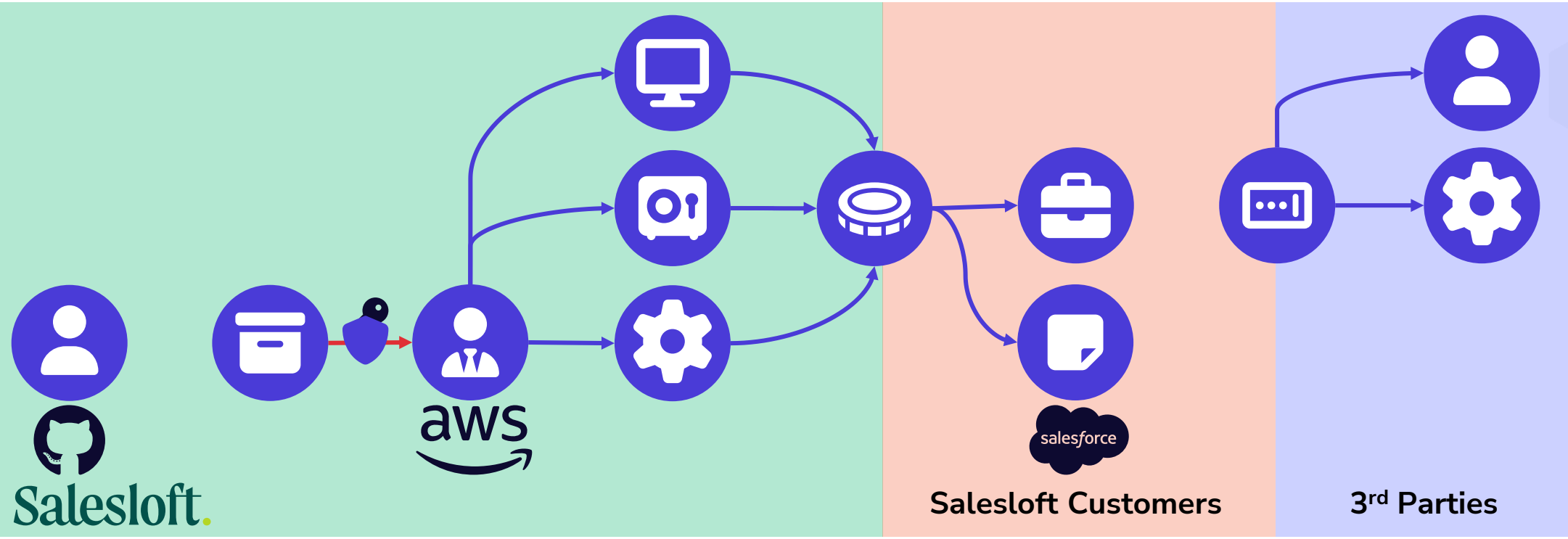
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example: Add Additional Security Controls to the Security Dependency

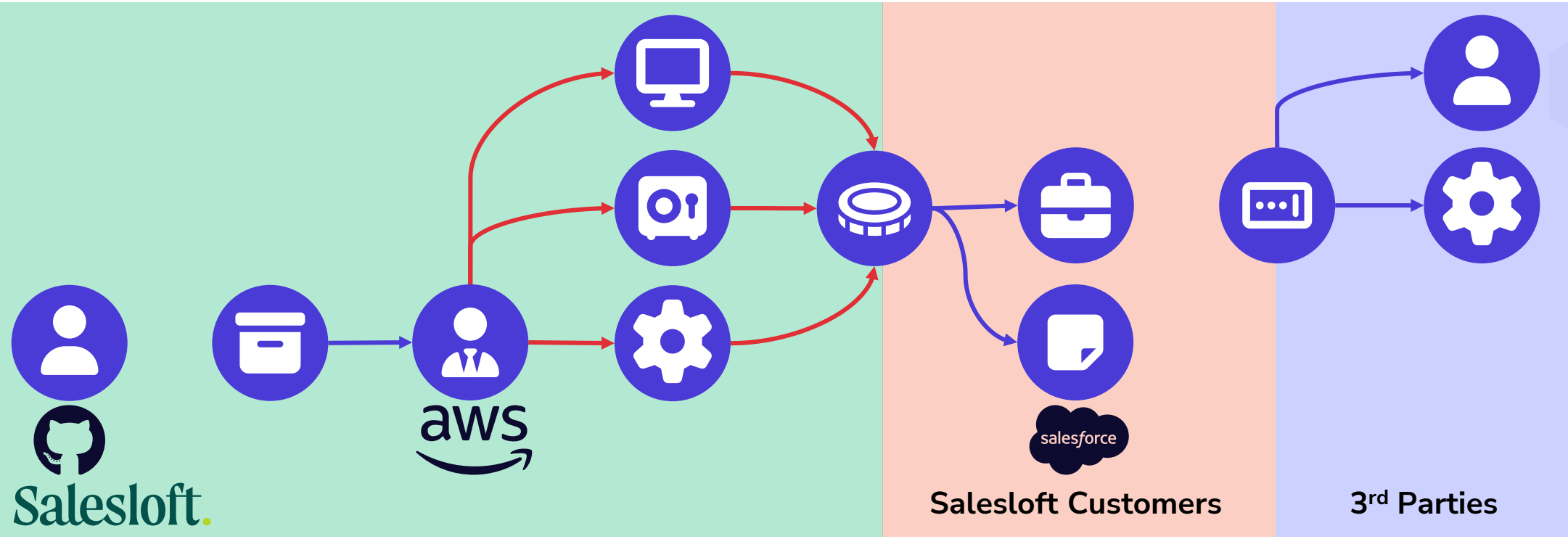
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example

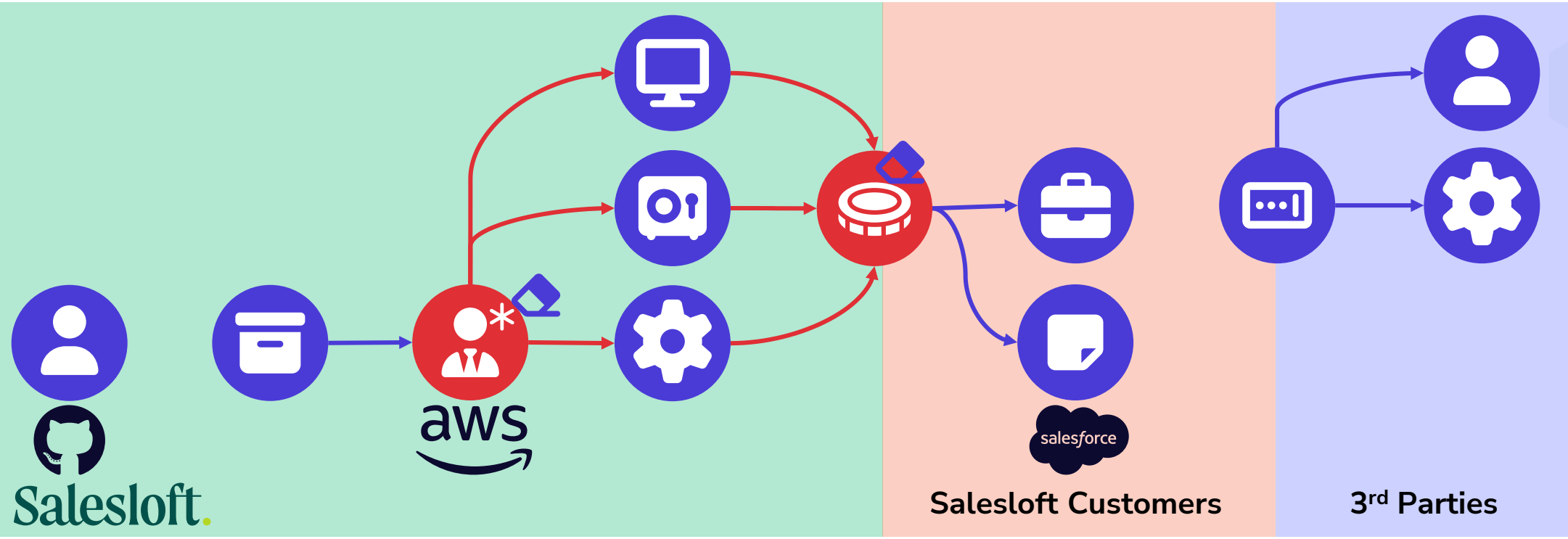
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example: Remove Functionality or Reduce Sensitivity From the Resource

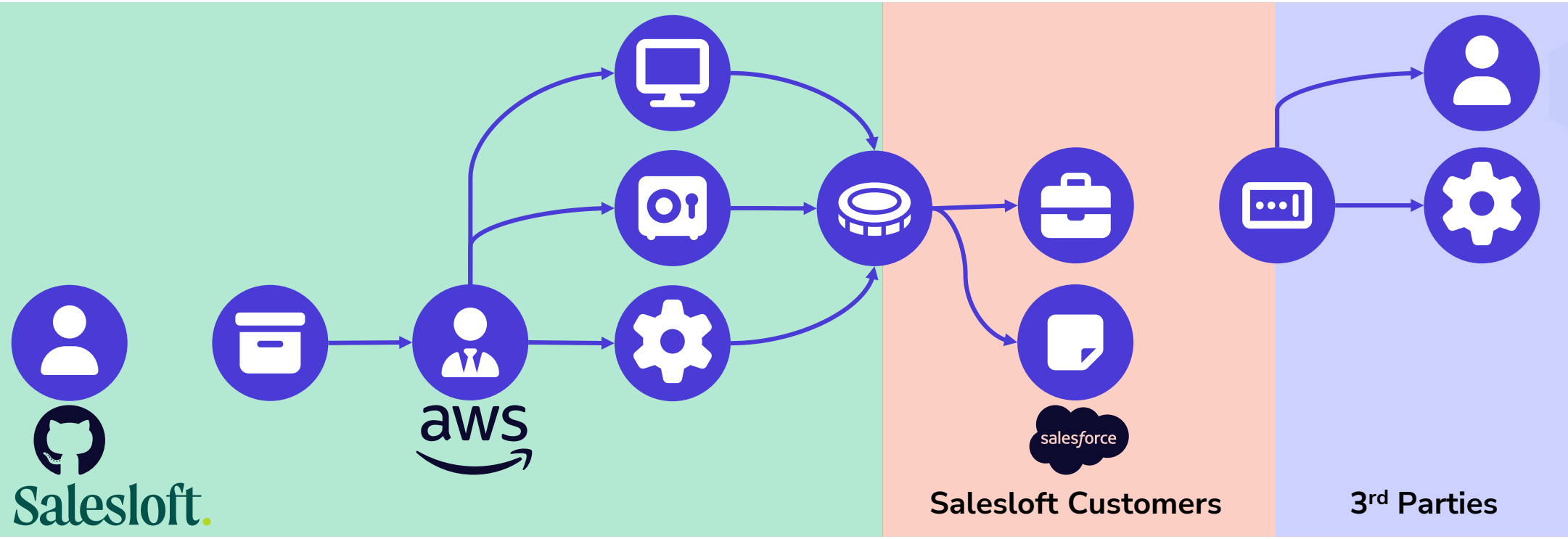
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example: Post-Remediation View

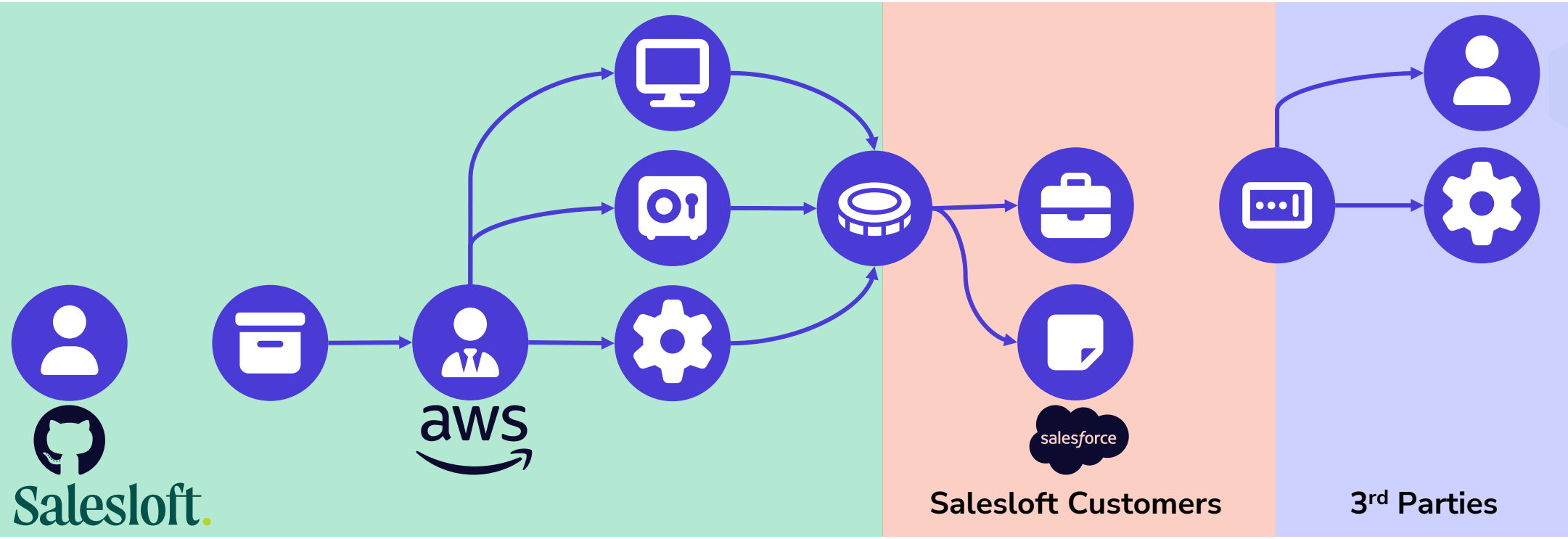
- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured



OpenGraph as the Future-Proof Strategy

Salesloft Example: Post-Remediation View

- Guiding Principle:
  All security dependencies must be as trustworthy as the object being secured
- **An Attack Path is a chain of control relationships *with at least one Clean Source Principle violation***



Conclusion

- Identities in motion are ready to access resources, and they are, therefore, the attackers' preferred target
  - Attackers target components that hold or generate ephemeral credential material, such as devices and hybrid identity infrastructure
- For attackers, authentication is downstream from authorization just as much as authorization is downstream from authentication
  - Tell me what I can access, and I'll tell you whom I can become
- The attack graph is an effective tool for identifying hybrid paths, identities in motion, and security dependencies
- OpenGraph can help model complex systems and identify clean source principle violations
  - Remove the security dependency or equalize the trustworthiness level of the resource and the security dependency
- Attack Path Management is not removing edges; it's all about fixing clean source principle violations
  - The goal is not to eliminate all paths, but to ensure that any remaining paths are aligned with the intended trust model

Thank you!

Please scan the QR code to provide feedback for this session

Hybrid Attacks and Identities in Motion: The Anatomy of Modern Attack Paths